1:45392363

WYDZIAŁ FIZYKI
i INFORMATYKI STOSOWANEJ
Uniwersytet Łódzki

Adrian Ambroziak

Kierunek: informatyka
T b ; informatyka stosowana
Specjalizacja: bazy danych i aplikacje internetowe
Numer albumu: 353144

Utwardzanie serwera sieciowego opartego o system Linux

Praca inżynierska
wykonana pod kierunkiem
dr. hab. Kordiana T
w Katedrze Fizyki Teoretycznej
WFiIS V

2019

STRESZCZENIE

W pracy przedstawiono nowoczesnych mechanizmów c b systemu Linux na b dystrybucji CentOS 7.6, Debian 9.8.0 oraz Fedora 29 ze szczególnym ieniem c b lokalnego i sieciowego systemu. Przeanalizowano metody zabezpieczania serwerów, których konfiguracja b - czyli web, poczty i serwera plików, a b omówiono b b dla systemu Linux. [b b pracy jest opis procesu konfiguracji serwerów w celu b b systemów, który b b pracy dyplomowej. Celem pracy jest b (hardened) serwera opartego o system Linux oraz stworzenie instrukcji b b b utwardzonego serwera (od etapu instalacji do chwili oddania do b b* oraz dokument b cy c b administracyjne i b b/

Słowa kluczowe: Linux, c - utwardzanie serwerów

HARDENING OF A LINUX-BASED NETWORK SERVER

The following thesis presents an overview of modern security mechanisms of the Linux system on the example of Centos 7.6, Debian 9.8.0 and Fedora 29 distribution with particular emphasis on local and network security. The methods of securing the most frequently configured servers, i.e. web, mail and file server, as well as the existing solutions for Linux were analyzed. The main part of the paper is a description of the process of server configuration in order to "harden" the systems, which was a practical part of the thesis. The aim of this work is to implement a hardened server based on Linux and to create an implementation manual for the hardened server (from installation to commissioning), as well as a document setting out "good administrative practices" and usage policy.

Keywords: Linux, security, servers hardening

Spis

X 1
D ! ! b ! b 3
1. B !c ЫM ! teoria. 4
1.1. System operacyjny Linux 4
1.2. C ! b 5
1.2.1. Kontrola nad rozruchem systemu 5
1.2.1.1. BIOS/UEFI 6
1.2.1.2. Program rozruchowy GRUB2 6
1.2.1.3. Zabezpieczenie programu rozruchowego GRUB2 8
1.2.1.4. Aplikacja Systemd 8
1.2.2. J b Ы ! ! ! b 10
1.2.2.1. V ! ! 10
2/3/3/3/!Q Ы ! ! ! 12
1.2.2.3. Q Ы b 13
1.2.3. L Ы b ! b ! ! 14
1.2.3.1. Ob Ы ! b Ы b ! b ! ! 15
1.2.4. Q Ыc Ы ! 15
1.2.4.1. AppArmor 18
1.2.4.2. SELinux 20
1.2.5. Kontrola antywirusowa 22
1.2.5.1. ClamAV 22
1.2.6. Monitorowanie dzienników systemowych 23
1.2.6.1. E ! b 23
1.2.6.2. Analizowanie i korelowanie dzienników 25
1.3. C ! 27
1.3.1. Zabezpieczenie logowania sieciowego 27
1.3.1.1. [b ! 29
1.3.1.2. L b ! ! !TTI 29
1.3.1.3. L b !c ! ЫTTI 30
1.3.1.4. L b Ы ! b ! !S TB! ! ЫTTI 30
1.4. C ! Ы c 31
1.4.1. Apache 31

1.4.2. PHP 34
1.4.3. MariaDB 35
1.5. C ! 35
1.5.1. Postfix 36
1.5.2. Dovecot 37
1.5.3. SpamAssassin 37
1.5.4. Filtrowanie ! !b b !T 38
1.5.5. Filtrowanie antywirusowe poczty ClamAV 39
1.5.6. [bc ! !Gb 3c b 39
1.6. C ! 40
1.6.1. Samba 40
2. Instalacja, konfiguracja i zabezpieczenie wybranej roli sieciowej w praktyce. 42
2.1. Serwer web 43
2.1.1. Apache 43
2.1.2. PHP 46
2.1.3. AppArmor 47
2.1.4. Serwer baz danych MariaDB 49
2.2. Serwer poczty 51
2.2.1. SELinux 51
2.2.2. Postfix 51
2.2.3. Dovecot 55
2.2.4. SpamAssassin 58
2.2.5. Filtrowanie ! !b b !T 61
2.2.6. Filtrowanie antywirusowe poczty ClamAV 62
2.2.7. Instalacja i konfiguracja Fail2ban 66
2.3. Serwer plików 71
2.3.1. Samba 71
2.4. J b b b ! !) ! b ! b b ! ! ! b b ! b b*/ 72
2.5. E c ! b !b b ! ! b b b/ 94
3. Podsumowanie 98
4. Bibliografia 101
4.1. Q c b ! ; 101
4.2. Strony internetowe: 101

Wstęp

C serwerów zawsze c b m tematem. W dzisiejszych czasach jest nawet bardziej istotne dawniej. Liczba b zabez w postaci b b - ataków DDoS czy b baz danych wzrasta w tempie geometrycznym. Nawet systemy GNU(Linux), które tradycyjnie c mniej podatne na problemy, przedmiotem ataków. w czasach, o których na - komputerowego hackingu. Wiele w naszym codziennym odbywa w Internecie b komunikatorów, tworzymy blogi, strony internetowe, tworzymy multimedialne, korzystamy z portali - konsumujemy , gramy w gry, czytamy b - czy robimy zakupy. L b z tych b b bazuje na serwerach umieszczonych w centrach danych, do Internetu, a te serwery stale przedmiotem ataków. [b b i ryzyko we - globalnej sieci komputerowej oraz , jaki b na b- który ma do niej - - kiedykolwiek /

C pod b historie osób takich jak b by Kevin Mitnick, b b na to, coraz b wielu hakerów jest zysk. Luki zero-day w popularnych aplikacjach, czy bazy danych b b popularnych serwisów, b b b danych osobowych, sprzedawane za , a nawet setki dolarów w Darknet na stronach tzw. dark market. Coraz czyta o trojanach, które b pliki, za których odszyfrowanie hakerzy b okupu w kryptowalutach. Zamiast czarnej bluzy z kapturem haker garnitur i b b dla organizacji terrorystycznej, dla , jak i dla wojska. Internet na XX i XXI wieku ulega zmianie, tak samo (ang.) *hacking* przemianie i b b b szpiegowskiej, a b b b wojennych. Nawet Polska w ramach obrony terytorialnej tworzy wojsko obrony cyberprzestrzeni, jako komponent, który osobom b kariery informatycznej na rynku cywilnym i cie c na rzecz c Polski w cyberprzestrzeni.

W ostatnich latach b b hakerów b b b coraz bardziej b b- do tego stopnia, informacje o zorganizowanych atakach hakerskich na sieci energetyczne czy - a b nuklearne, nie b do b / Hakerzy coraz zorganizowani w grupy dobrze finansowani i znakomicie wyszkoleni. E b - zaawansowanymi programami, które sami, b

opracowane metody b b b/ D b b napisane dla takich organizacji jak CIA, NSA, czy KGB b b w hakerów i wykorzystywane zaledwie po roku, lub dwóch od ich napisania. Zdarza - informacje o takich programach ujawnianie przez c pracowników c wywiadowczych, jak b to miejsce w przypadku programu PRISM ujawnionego przez c pracownika CIA Edwarda Snowdena. Ile z takich programów b w b @Tego nie wiemy. Oznacza to, model b powinien b ataków hakerskich z ostatniego roku.

Obecnie przeprowadzanych b b jest w zautomatyzowana. Cel jest b iej jeden zbudowanie jak b go zbioru zainfekowanych maszyn tak, aby b je c b do nowych ataków. Przetwarzanie danych w chmurze b do jeszcze rozmycia sieci i / W b rozdzielenie tymi sieciami c b poprzez b b (ang. *demilitarized zone* DMZ), w której administrator b b firewall na granicy obiema tymi sieciami. Wtedy hakerowi c trudniej serwer i b go do szafy serwerowej w serwerowni w firmie. Teraz takim jak Azure, Amazon Cloud, czy hostingowi, jest to kwestia kilku / Ob b - serwery w chmurze ze c przez b i b b tak, jakby b pakiet c b przez c - która z zasady nie jest bezpieczna. Ochrona systemów informatycznych polega na zastosowaniu odpowiednich metod bc b poszczególne warstwy. Ana c systemu, b b zabezpieczenie fizycznego do - zabezpieczenie aplikacji - komunikacji itd. Oprogramowanie, które jest b systemu komputerowego, to system operacyjny, pod którego nadzorem b aplikacje wykonawcze. X b ze na to, system operacyjny jest b b b systemu informatycznego, jego c jest bardzo istotne. Z tego powodu pierwsze b b b ane z systemu komputerowego zabezpieczenia warstwy systemu operacyjnego. W zb od specyfiki projektu wymiar i b owo b b do aktualizacji oprogramowania. Istnieje jednak bardzo wiele sytuacji, które b b zastosowania wyszukanych b i technik dla zapewnienia b poziomu c twa systemu operacyjnego.

Cel i układ pracy

W z b - w niniejszej pracy temat mechanizmów c b/ Systemy operacyjne znacznie c - z tego powodu b b- które b dla nich stworzone, b / Ze na bardzo c systemów operacyjnych, które b przeprowadzenie b a przy tym wnikliwej analizy wszystkich mechanizmów, w pracy skoncentrowano na nowoczesnych b c b przygotowanych dla systemu Linux. System ten jest powszechny w b b serwerowych, wbudowanych, a b na b mobilnych. Wysokie c - które sk b b na b Linux ma w wielu zastosowaniach istotne znaczenie - co czyni b b szczególnie / Celem pracy jest wdro b (ang. *hardened*) serwera opartego o System Linux i zapewnienie c b lokalnego i sieciowego systemu. Aby b b b zadanie, w pierwszej przeanalizowano najnowsze dystrybucje Debian 9.8.0, CentOS 7.6, Fedora 29 pod zastosowanych w nich ochrony. Podczas eksploracji mechanizmów c b zidentyfikowano zapotrzebowanie na b b do ochrony ww. systemów operacyjnych. W kolejnym kroku przeprowadzono b b b problemu. Wnioski na podstawie b do b b b b i zaprojektowania na tej podstawie instrukcji b b b utwardzonego serwera od etapu instalacji do chwili oddania go do b b oraz dokumentu b dobre praktyki administracyjne i b b/ V b b niniejszej pracy w naturalny sposób odzwierciedla przebieg procesu. W rozdziale I, który jest - zaprezentowano rodzaje bc b z c lokalnym systemu na b ww. dystrybucji Linux, poprzedzone celów i potrzeb, które b do b konkretnych b / Kolejny b koncentruje na praktycznej stronie c b w b od wybranej roli sieciowej serwera i przedstawia typowe zagadnienia oraz b b b wybranej roli. S b ten b b i b poszczególnych elementów w celu zabezpieczenia serwera, a b dokumentem b b informacje, które b b praktyki, którymi powinien na b b administrator oraz b b serwera.

1. Aspekty bezpieczeństwa Linux – teoria.

1.1. System operacyjny Linux

Linux jest komputerowym systemem operacyjnym (OS) podobnym do Unix OS i w przypadków jest zgodny z POSIX-em i jest rozwijany w modelu wolnego i otwartego oprogramowania i dystrybucji. Linux b pierwotnie stworzony tak, aby c podobny do systemu Unix. Oba b podobne b b do b z systemami, b b programistyczne, b systemów plików i inne kluczowe komponenty. Jednak Uniks nie jest wolny. Przez lata b wiele systemów operacyjnych, które c b c "uniksopodobne" lub "kompatybilne z uniksem", ale Linux b b najbardziej udany, znacznie b b swoich poprzedników. Linux jest najbardziej znanym i b b systemem operacyjnym open source. Dla celów niniejszej pracy, b terminu "Linux" w odniesieniu do b Linuksa, ale zestawu programów, b i - które zazwyczaj razem z Linuksa, aby b wszystkie c komponenty w funkcjonalnego systemu operacyjnego. Pod wieloma b Linux jest podobny do innych systemów operacyjnych, takich jak Windows, OS X lub iOS. Podobnie jak inne systemy operacyjne, Linux posiada graficzny interfejs i rodzaje oprogramowania, do korzystania, z których przyzwyczajeni na innych systemach operacyjnych, takich jak aplikacje do przetwarzania tekstu.

Niemniej jednak, Linux od innych systemów operacyjnych na wiele sposobów. Przede wszystkim Linux jest oprogramowaniem typu open source; kod b do tworzenia Linuksa jest darmowy i publicznie do b b- edytowania i dla z odpowiednimi b istnieje b b w jego tworzeniu. Wreszcie, Linux jest inny w tym, b podstawowe elementy systemu operacyjnego Linux na powszechne, istnieje wiele dystrybucji Linuksa, które b b opcje oprogramowania. Oznacza to, Linux jest niesamowicie konfigurowalny, b Linuksa c b podstawowe komponenty, takie jak to, który system b grafi - - oraz o tym, jakie aplikacje zainstalowane. Na ten system Linux istnieje niewielka wirusów. To jest powód, dla którego b b Linuksa do celów tej pracy.

1.2. Bezpieczeństwo lokalne

W tym rozdziale b ogólne zasady c b- które b zastosowane podczas zabezpieczania serwera Linux. Ob do omówienia jednego z b problemów bc - z którymi b b na co , a mianowicie b / W kolejnych b b na b b bc z naciskiem na b lokalnego systemu plików, c b kontroli i mechanizmy z b zapewnianie przez LSM (ang. *Linux Security Modules* N C b Linux), które b b systemu Linux. Ob do kontroli antywirusowej realizowanej przez skaner antywirusowy ClamAV. Ostatnim etapem tego b c omówienie sposobów monitorowania, analizy i korelacji dzienników systemowych i dzienników b /

1.2.1. Kontrola nad rozruchem systemu

W tym podrozdziale b mechanizmy b b b systemu Linux, aby b - co dzieje w momencie rozruchu (ang. *boot*) systemu. Q b b poszczególne etapy tego procesu i b sposoby uruchamiania systemu w trybach, a b c b - jak b i poprawnie b rozruch systemu.

Rozruch systemu tzw. b b polega na b b trzech oddzielnych, lecz wzajemnie b ze c elementów: BIOS (ang. *Basic Input/Output System* podstawowy b 0 * lub UEFI (ang. *Unified Extensible Firmware Interface* ujednolicony rozszerzalny interfejs oprogramowania *- programu rozruchowego (ang. *boot loader*) oraz wczytywania systemu operacyjnego. Te trzy elementy odpowiedzialne za poszczególne etapy, które b w b sposób:

1. BIOS/UEFI jest odpowiedzialne za uruchomienie i sprawdzenie -
2. Program rozruchowy (GRUB2) pozwala c b zainstalowany system operacyjny,
3. Systemd odpowiada za wczytanie i b systemu operacyjnego.

Nie jest to zjawisko specyficzne tylko i dla systemów z rodziny Linux. Wiele systemów operacyjnych wykorzystuje podobny zestaw funkcji i / Nowe

za b c b UEFI, które zb je starsze BIOS, wykorzystywane we eniach. Zarówno BIOS, jak i UEFI c funkcje i obydwa, b b od starszego, czyli BIOS.

1.2.1.1. BIOS/UEFI

Po przycisku zasilania serwera b rozruch, za który odpowiada BIOS b w niewielkim b scalonym na - zwany b BIOS. BIOS przeprowadza podczas rozruchu podstawowe testy systemowe, albo POST (ang. *power-on-self-test* samodzielny test po zasilania), aby b poszczególnych elementów komputera takich jak b b - dyski twarde, b b czy b b / E w pierwszej przeszukiwane zamontowane dyski twarde, a w dalszej sprawdzane b ki, takie jak b CD/DVD, czy b USB. Tutaj istotne dla c b jest b i USB, pozostawienie tylko dysków twardych w ustalonej przeszukiwania i zabezpieczenie BIOS b w celu b wprowadzenia zmian osobom do tego b / Jest to pierwsza linia obrony przed atakiem od / Przy czym c b jest, aby nie bc b dysku twardego b w BIOS, lecz jedynie b b - co sprawi, BIOS nie c b o b po b zaplanowanym restarcie serwera.

Nowsze b b wbudowany interfejs UEFI. S b w rozruchu BIOS i UEFI jest niewielka. Mechanizmy b b b obu jednak inne. J rodzaje oprogramowania, które b do OS (ang. *Operating System* system operacyjny) poprzez program rozruchowy. W interfejsie UEFI jest mechanizm c . Podpisane programy rozruchowe oraz przed wczytaniem weryfikowane za kluczy publicznych/prywatnych. W swoich b b na dwóch starszych modelach laptopów z Debian i CentOS b jest BIOS, nowszy laptop z Fedora posiada UEFI.

1.2.1.2. Program rozruchowy GRUB2

Gdy b zainicjowane wszystkie do oraz zastosowane b podstawowe ustawienia, serwer jest gotowy do rozruchu

systemu. Zarówno BIOS jak i UEFI b kod wgrany podczas instalacji dystrybucji. Kod ten jest tzw. programem rozruchowym i musi c umieszczony w odpowiednim miejscu na dysku. BIOS w tym celu b MBR, który b b b rekordem rozruchowym umieszczonym w specjalnym sektorze dysku twardego zwanym sektorem rozruchowym. Po uruchomieniu GRUB2 znajduje, wczytuje i przekazuje system operacyjny do dyspozycji administratora systemu. Proces ten b b z dwóch etapów. Jak b podczas omawiania rekordu MBR, istnieje wydzielony obszar przed bc partycji o rozmiarze 466 bajtów, w którym przechowywane informacje o pierwszym etapie. W tym b obszarze znajduje plik o nazwie boot.img. Ob po uruchomieniu boot.img BIOS wyszukuje i wykonuje kod zawarty w pliku core.img. E lnie plik core jest umieszczony w przerwie MBR (ang. *MBR gap*). Jest to MBR a b / S pliku core.img jest uzyskanie do katalogu /boot/grub i wczytanie zawartych tam / Plik ten menu rozruchowe i jest w stanie b docelowy system operacyjny.

W przypadku UEFI proces uruchomienia systemu przebiega w inny sposób. UEFI potrafi b bc GPT, a b b oraz kod rozruchowy zawarty w katalogu /EFI/ na partycji systemowej EFI. Interfejs UEFI, w do BIOS, ma b b - na której podczas instalacji kopiowane program rozruchowy oraz rozruchowe.

W momencie, gdy interfejs UEFI jest gotowy, to szuka programu rozruchowego na wspomnianej partycji. W przypadku zostanie odnaleziony plik /EFI/fedora/grubx64.efi. Na tym etapie program rozruchowy wykrywa b /boot, na której przechowywane jest oprogramowanie GRUB2 i wczyta b b pliku core.efi, co spowoduje menu GRUB2. K odczekamy, b odliczanie, to program rozruchowy wczyta systemu. W kolejnym etapie GRUB2 wyszuka plik binarny b (vmlinux-<numer_wydania>), b wczyta do b komputera plik initrd.img, w którym przechowywane sterowniki wymagane przez do c komputera. Wczytanie pliku initrd.img jest b b przez program GRUB2, w b nad serwerem przejmuje - które odpowiedzialne jest za b procesu rozruchu poprzez b - w tym dysków twardych. Zostaje uruchomiony system operacyjny i b b e specjalnego programu Systemd.

1.2.1.3. Zabezpieczenie programu rozruchowego GRUB2

GRUB2 b rozruch w trybie pojedynczego b (ang. *single-user mode*), który nazywany jest b trybem administracyjnym (ang. *maintenance mode*). Tego trybu b w przypadku awarii systemu operacyjnego serwera. W tej sytuacji ograniczony jest jedynie do konta root (konto administratora z b uprawnieniami) i zazwyczaj poziomu konsoli systemowej. V b to b z dyskami i plikami bez obawy o b konfliktów lub interferencje ze strony innych / Uruchamianie systemu w trybie *user-single mode* przebiega nieco odmiennie w dystrybucjach CentOS/Fedora i Debian. We wszystkich przypadkach b jest podobne menu GRUB2, w którym jest wybranie b systemu, które b zostanie wczytane. Dystrybucje Fedora oraz CentOS b b dwie opcje, czyli wybór b b a b b trybu odzyskiwania (ang. *recovery mode kernel*). W przypadku Debian widoczny jest wpis podmenu nazwany Opcje zaawansowane dla systemu Debian *(*ang. *Advanced Options for Debian GNU/Linux*). W omawianym b wykorzystam standardowe Debian 9.8.0. Aby b wybrany kernel trzeba klawisz E. X zostanie kod konfiguracji tego b- w tym ustawienia jego lokalizacji i parametrów. Identyczne informacje b w pliku grub.cfg. W tym konkretnym przypadku interesuje nas wiersz linux /vmlinuz-4.9.0-8-amd64 Za klawiszy b na koniec tego wiersza. K b rozruch w trybie pojedynczego b- tutaj wyraz single. Po b kombinacji ctrl+x b w w tryb pojedynczego b/ W tym momencie warto b na fakt, niezabezpieczony program rozruchowy b zmodyfikowany w trakcie rozruchu przez c b wrogie zamiary. GRUB2 daje zdefiniowania b b- co sprawia, wszelkie zmiany w przygotowanym procesie rozruchowym c b b jego wprowadzenia. Zabezpieczenie GRUB2 jest z podstawowych zasad c b i b standardem. Podczas b audytu b c ten punkt jest sprawdzany jako jeden z pierwszych. Zabezpieczenie programu rozruchowego GRUB b ! ! ! ! b ! ! ! b b b utwardzonego serwera.

1.2.1.4. Aplikacja Systemd

W dalszym etapie startu systemu, gdy uruchamiane gi systemowe, b b serwisy Systemd, które dystrybucjami. E temu

Inicjator ten wykorzystuje do swojego b b b celów (ang. *targets*). Cele odpowiedzialne za grupowanie b b / Powszechnie b cele to *boot*, *rescue*, *multiuser*. Cel *multiuser* wykorzystywany jest w sytuacji, gdy chcemy system, w którym wszyscy w stanie za b i b z / W tym stanie sieciowe, ssh i logowania, które b elementami stanu *multiuser*.

1.2.2. Implementacja polityki kont i haseł

I b b to jedna z podstawowych metod uwierzytelniania. I b b powinny c znane tylko i takie, aby nie b c ich b / Mimo, obecnie techniki b b b b bardzo i szybkie, to nadal wybierane b b- które proste i b do b b. Ataki na b b b wyrafinowane. Metody brute force b ze b b setki lub ataki - b na podejmowaniu wielu prób od b b b b jak to (w przypadku b b- które jest 6- c one od 000000 i c b wszystkich kombinacji, b do 999999 oznacza to milion prób) . N b b - to b c czasu, ale pod b - nowoczesne komputery w stanie b setki lub miliony prób b b b b na - to b - b b krótkie lub takie, które b b w - dla napastnika trywialne do b b/ Niestety, w wielu firmach stosuje b b b i w rezultacie c b bc b b- b do b b dla c / W dalszej tego b b b ograniczenia stosowane w polityce b i b o tym, co w dzisiejszym sprawdza, a co nie. Na koniec c b /

1.2.2.1. Użytkownicy i grupy

Linux b wielu z b c przy oddzielnych sesji interfejsów tekstowych lub graficznych. E do serwera i jego zasobów kontrolowany jest poprzez konta i grupy. Konta tworzone pod b systemowych oraz b do uruchamiania i utrzymywania / Q b podczas instalacji serwera pocztowego zostanie b utworzony mail b b z / W Linux wykorzystuje b grup,

czyli zbiorów podobnych / V c b jednej lub liczby grup i zazwyczaj umieszczani w grupie, aby mogli b do wyznaczonych zasobów. Q b wszyscy - którzy powinni do systemu transakcji finansowych, b dodani do wspólnej grupy nazwanej transakcje. Istotni zarówno - jak i grupy, dlatego b b b b kont i tworzenia grup oraz ich b b /

W Linux b posiada konto, które zazwyczaj jest chronione b / Podczas tworzenia powstaje b katalog domowy , w którym b swoje dane; jest to b lokalizacja dla plików konfiguracyjnych wielu aplikacji. V przypisani do grup, czemu do dodatkowych zasobów lub / Informacje o b i grupach przechowywane przede wszystkim w dwóch plikach: zawiera informacje o - a o grupie. J standardowe grupy b uprawnienia (root) w systemach Linux takie, jak: admin, wheel i sudo. L b serwera linuksowego musi b do co najmniej jednej grupy, zwanej (ang. *primary group*), jednak c innych grup, tak zwanych grup dodatkowych (ang. *supplementary group*).

Prawo b pliku dla b i grupy przy pomocy polecenia chown. Jedynie konto root ma zmiany b pliku) b jest rozszerzenie tego prawa przy komendy sudo, której b w sekcji A.2). E b jest b komenda chgrp. V b jej b b pliku do grupy, z tym b prawo b jedynie grupie, do której b / T b b tego polecenia b b ;

Tworzenie i grup jest bardzo proste: w pierwszym przypadku b jest polecenie , a w drugim . Ponadto istnieje modyfikowania kont i grup przy pomocy komend, odpowiednio: i . Natomiast konta b b przy polecenia , a usuniemy, b z komendy . I b ustawiamy .

1.2.2.2. Polityka kont użytkowników i grup

Administratorem w Linux c tylko root. Administrator ma prawa i nikt mu ich nie c b / L b powinien swój katalog domowy. E profile tworzone w katalogu /home i b jest nazwa b- np. /home/ , jednak nie b ograniczenia, które brak zmiany lokalizacji i nazwy katalogu domowego. X jest tutaj root, który katalog domowy ma w folderze /root. Zalecanym b podczas instalacji systemu jest, aby katalogi domowe b b na osobnej partycji przeznaczonej dla katalogu /home, na której uruchomiony jest system quota, czyli mechanizm sterowania b miejsca na dysku dla poszczególnych i grup. V b do jednej lub wielu grup i prawa do plików, których nie b b - b od tej b / Pliki utworzone przez b b do jego aktualnej grupy. Grupa ta jest inicjalizowana w momencie otwarcia sesji, plikowi /etc/passwd.

Nazwy kont powinny c niepowtarzalne i zgodne z aktualnie b / V powinni silne, losowo wygenerowane b b oraz numery UID i GID b dla b b/ Nie b b kont - b od tego, czy chodzi o konta - konta interfejsów webowych, czy konta / Konta b b wspólne b b w zespole, co samo w sobie jest b / D konta takie uprzywilejowane, dlatego w przypadku, gdy jeden z go - powstaje potrzeba utrzymywania b wspólnych kont oraz bezpiecznej dystrybucji nowego b b dla wszystkich . Indywidualne konta b b b - jaka osoba b b b na konto i pozwala z b - czy b b destruktywne b b b/ X konta nie konieczne w b nowoczesnym systemie, w którym zagadnienia z b z c b istotne znaczenie. Zawsze b b do tworzenia uprzywilejowanych ról i przypisywania tym rolom indywidualnych kont. W przypadku kont powinno to kont grup lub ról, do których indywidualni za b b sudo. Natomiast w przypadku innych administrator c b jest do zadbania o utworzenie uprzywilejowanej grupy, do której b doda b indywidualnych /

Tymczasowe blokowanie kont powinno b poprzez polecenie: . Odblokowanie konta b poprzez wykonanie komendy: .

N ! ! ! b ! - wystarczy b b lub inny znak na zaszyfrowanego b b b w pliku /etc/shadow albo w pliku /etc/master.passwd. E ! ! ! c! ! ! b b! ! c ! -! ! ! ! ! ! b ! b ! w ten c! b b/ X ! c ! M ! b ! b ! bc b ! ! c b ! b b! b! ! ! ! b ! /! Opcja L (ang. *lock*) dodaje znak ! b! ! b b ! b b! w pliku /etc/shadow, natomiast opcja U (ang. *unlock*) go usuwa. Innym sposobem b tymczasowo konta jest b b programem, który komunikat o blokadzie konta i b - jakie b w takiej sytuacji.

1.2.2.3. Polityka haseł

K z najbardziej istotnych kwestii w przypadku polityki b jest koncepcja wprowadzenia b b b b- co ma na celu liczby kombinacji w przypadku próby b b b b przez napastnika b b atak / [liczby znaków w b sprawia, atak staje trudniejszy. [minimalnej b b b c tylko o jeden znak znacznie b c kombinacji. Jednak trzeba pod b fakt, napastnik - który potrafi b milion prób na - b b b 6-znakowe b w 5 minut, a 8-znakowe w 2,5 dnia. Natomiast sprawdzenie wszystkich kombinacji dla b b 12-znakowego zajmie 3026 lat. To b z tego powodu napastnicy znacznie na zastosowanie ataku zamiast / K 8-znakowe b jest ze b- to b b go za ataku zajmie wiele dni, natomiast b b go potrwa kilka sekund. Atak b poprzez wprowadzenie wymagania b b/ Ob b b - aby b b b litery i przynajmniej lub b wielkich liter z b oraz znakami specjalnymi. Co prawda b b znacznie b b c kombinacji b - b ten wzrost jest wielokrotnie mniejszy w porównaniu ze minimalnej

b b/ 12-znakowe b pisane b literami ma o

kombinacji 8 znakowe b o /

Wymuszenie rotacji b co b b lub i wprowadzenie obowi wymogu, aby nie b c b dwa razy takiego samego b b jest b skuteczne. Koncepcja rotacji b wynika z pragmatycznego b uba zmienza naszenza do faktu, nawet b zostanie b b - to to napastnik c b tylko ograniczony czas na to, aby b z uzyskanego - zanim b zostanie zmienione. Jednak, gdy napastnikowi uda b b b i b do konta, to natychmiast do b b b/ Zanim b zostanie zmienione, napastnik dokona szkód i zniknie. Ponadto hakerzy zwykle w uzyskany po to, aby rodzaj b (ang. *backdoor*), które da mu nawet wtedy, gdy b ulegnie zmianie. Wprowadzenie rotacji b b b c - c c b nowe b - które c bardzo podobne do poprzedniego. W strategii dla zaleca prostoty. I b b co najmniej 12 znaków, bez b b co do / Dodatkowo b b b do wybierania jako b fraz (ang. *passphrase*) zamiast (ang. *password*). I b w postaci frazy to kilku / Najlepiej, c one losowe. I b b root i administratorów b b przynajmniej co 6 swey30[jnte - za b razem, gdy - kto b do nih ysunwek jak>] TJET

ery ac st

1.2.3.1. Narzędzia do monitorowania zmian lokalnego systemu plików

API b systemu plików b aplikacjom b plików i otrzymywanie b o ich otwarciu, modyfikacji, lub zmianie nazwy. To bardzo pomaga aplikacjom, b zanim takie b b do monitorowania b w systemie plików b - takie aplikacje b c wielokrotnie b dysk w celu wykrycia wszelkich zmian, co b wysokim dysku i CPU. S b jest kilka b - które b b do monitorowania b w systemie plików.

FAM (File Alteration Monitor) - jest to jeden z najstarszych monitorów b /X b zdarzenia do aplikacji, gdy wprowadzane zmiany w plikach lub katalogach, które aplikacja b b b w celu monitorowania. Jest skomplikowany.

Gamin - nowszy i prostszy FAM. Stara c kompatybilny z FAM, nie przy tym wielu niejasnych funkcji. Jest utrzymywany i szeroko w wielu dystrybucjach Linux. Jest - ale rozwój i testowanie skupia na Linux. Posiada wsparcie BSD i b go b w Portach FreeBSD.

dnotify - wprowadzony od wersji b Linux od wydania 2.4. N b tylko katalogi i wymaga utrzymywania otwartego deskryptora plików do katalogu, który chce b / [b zdezaktualizowany przez inotify.

inotify - b dnotify. Jest podsystemu b Linux i wchodzi w b b Linux od wydania 2.6.13. Jest szybki i lekki i powinien c we wszystkich dystrybucjach Linux.

Jednymi z stosowanych platform FIM Tripwire i OSSEC. Standardowym b FIM jest program mtree, który pozwala w prosty sposób b stan plików i zmian ich b b / Jest btwy do zintegrowania ze skryptami / Stworzenie platformy FIM a jej c b w czasie to dwie sprawy. Do przechowywania danych i odpowiadania na powiadomienia FIM potrzeba b odpowiedni proces.

1.2.4. Polityka bezpieczeństwa kontroli dostępu

Standardowy model kontroli od wielu lat pozostaje w mierze niezmieniony. Pomimo tego, wprowadzono do niego kilka b - to nadal jest

on b / Schemat tego modelu oparty jest na kilku podstawowych zasadach:

- Decyzje, które kontroli b od tego, który próbuje b b - a w niektórych przypadkach od wa tego b w grupie.
- Obiekty (pliki i procesy) b b b / X b b nad swoimi obiektami, jednak nie jest ona nieograniczona.
- Obiekty tworzone przez danego b jego b /
- Specjalne konto b o nazwie root b b jak b b obiektu.
- Tylko root b b pewne b operacje administracyjne.

W standardowym modelu b plik posiada b b i / X b b uprawnienia do swoich plików i katalogów przy pomocy polecenia . X b trzy podstawowe typy b ;

- odczyt reprezentowany przez r (ang. *read*),
- zapis symbolizowany w (ang. *write*),
- b b x (ang. *execute*).

X b pliku b- co z nim c b grupowy, czyli osoby b do grupy, która daje do pliku. Taki schemat pozwala na b plików i katalogów np. tego samego projektu.

E b root jest c warunkiem administracji systemem oraz elementem jego c b/ Zdalne logowanie na konto root powinno c zabronione, b logowanie na to konto nie pozostawia b zapisów operacji wykonywanych przez tego b/ Zaleca pozostawienie su) na konto root) oraz sudo. Polecenie su nie rejestruje wydanych jako root, ale tworzy wpis dziennika, na podstawie którego b kto i kiedy b b na jego koncie. Polecenie sudo jest programem, który powinien c zalecanym b - b pozwala na b - którzy dodani do pliku sudoers. E temu oni b polecenia z uprawnieniami root. Polecenie sudo rejestruje informacje o wykonanych poleceniach, komputerach, na których b one wykonane, osobach, które je - katalogach, z których

b uruchomione oraz o czasach, w jakich b b / Informacje te zazwyczaj zbierane przez demon syslog, lecz c zapisywane do innego, wybranego pliku. Warto b sudo dla b b za dystrybucji pliku sudoers na wszystkie serwery. Warto wtedy b c b o to, aby dystrybucja c b przeprowadzona za szerszego systemu b b b b oraz b za systemu monitorowania b plików. Warto b konta root i pozostanie tylko przy sudo. S anie to ma wiele zalet. Eliminuje naruszenia b b ka root a b brak zapisu informacji o tym, co b zmienione w systemie.

Model standardowy nie jest pozbawiony wad. Problemem jest to, zapewnia lub b c audytu i rejestrowania b / W prosty sposób b b - do jakiej grupy b dany - jednak niekoniecznie da - jakie uprawnienia daje w danej grupie. Oprócz tego nie ma b realnej metody, aby , w jaki sposób wykorzystywane rozszerzone uprawnienia, czy b wykonywane w ten sposób operacje. Z tego powodu zalecane jest rozszerzenie standardowego modelu kontroli o b b- które /

- PAM (ang. *Pluggable Authentication Modules*) interfejs obejmuje szereg bibliotek uwierzytelniania za metod.
- Kerberos, czyli sieciowe uwierzytelnianie kryptograficzne w postaci zaufanego serwera b b b kryptograficzne w celu uwierzytelnienia oraz / Zaleca stosowanie go razem z PAM.
- Listy Kontroli E (ang. ACL *Access Control List*).
- Docker b do konteneryzacji oprogramowania, b na rozdzieleniu procesów na hierarchiczne przestrzenie nazw, co pozwala na b procesu kontenera i odizolowanie go od innych procesów, co pozwala na uruchomienie go z uprawnieniami root bez obawy o to, zagrozi to innym systemu.
- MAC (ang. *Mandatory Access Control*) c b kontrola za zdefiniowanych /

- Kontrola oparta na rolach b b w skrócie jako RBAC (ang. *Role Based Access Control*) za warstwy sprawdzania ról /
- AppArmor
- SELinux

Te dwa ostatnie b b ze na to, b zastosowane w mojej pracy, jako b nowoczesnych mechanizmów kontroli /

1.2.4.1. AppArmor

AppArmor jest produktem firmy Canonical, Ltd., która wydaje c Ubuntu. Jest wspierany w dystrybucjach Ubuntu oraz Debian, a b b jako standard przez c SUSE. [b b to b na serwerze web, na którym znajduje Linux Debian 9.8.0 na zasadzie pewnego rodzaju MAC i jako standardowego modelu kontroli / Mimo tego, b jest dowolna konfiguracja, to AppArmor nie b zaprojektowany jako system zorientowany na b/ H wnym celem podsystemu AppArmor jest zabezpieczenie - poprzez ograniczenie szkód, które programy, w sytuacji, gdy ich zabezpieczenia b naruszone czy c b b b / Chronione przez AppArmor programy nadal b wszystkim ograniczeniom narzuconym przez model standardowy, b dodatkowo filtruje ich b b b poprzez profil AppArmor, który odrzuca wszystkie b b- profil ten musi b b wszystko, co wolno danemu procesowi. Programy, które nie b profili, takie jak b- nie b b b b - b b tak, jakby AppArmor nie c zainstalowany.

Profile AppArmor b w pliku /etc/apparmor.d i klarowne nawet bez b b systemu. X profili AppArmor korzysta z gotowych - które b b b b / AppArmor do plików i programów przy pomocy - czemu profile czytelne i nie b od b konkretnej implementacji systemu plików. Q to jednak jest pewnego rodzaju kompromisem. Q b c tutaj fakt, AppArmor nie rozpoznaje twardych b jako b do tych samych jednostek, na które b /

AppArmor jest efektywnym i b w b - które aktywnie chroni system operacyjny poprzez monitorowanie i ograniczenie do plików, sieci i wykonywania b b tzw. *linux capabilities (chown, setuid, itp.)*. K b w b sposób nie zmienia on zasad DAC (ang. *Discretionary Access Control*), czyli metody zabezpieczania, która polega na przypisywaniu konkretnym podmiotom) b - grupa, inni) konkretnych b / Dlatego, wszystkie pliki katalogu domowym danego b w systemie b flagi 777, albo b jest konto root, AppArmor nie c b swojej roli. Co prawda, AppArmor nie jest w stanie serwera przez wszystkimi expolitami, to system jest bardziej bezpieczny, gdy AppArmor jest - b do wielu (Apache, Postfix) gotowe profile, które b b b - co pozwala w prosty sposób bc serwer. Dodatkowo b zaawansowanej analizy statystycznej i b opartych na uczeniu - polityki AppArmor dla nawet bardzo aplikacji b w kilku godzin.

Podczas gdy Linuksa zapewnia c b i b do plików, MAC taki jak AppArmor zapewnia bardziej precyzyjne uprawnienia i przed wieloma nieznanymi b b / K w Linuksa lub innym demonie systemowym zostanie znaleziony c c b- dobrze skonfigurowany system AppArmor do krytycznych, które c podatne na ten problem.

AppArmor b b w dwóch trybach:

- egzekwowania (ang. *enforce*),
- b b b (ang. *complain*).

Egzekwowanie jest statusem produkcyjnym AppArmor, natomiast b b jest przydatna przy opracowywaniu zestawu opartych na rzeczywistych wzorcach b b b oraz przy naruszaniu zasad logowania. Jest on konfigurowany za plików tekstowych w stosunkowo przyjaznym formacie i ma uczenia innych c systemów kontroli /

X b AppArmor jest to, profile AppArmor b b procesy w oparciu o b aplikacji, b jest to b MAC oparta na nazwach . Tak AppArmor nie zapewnia b ochrony przed nieuczciwym lokalnym, który b plik wykonywalny do innej lokalizacji i go pod / Chroni to jednak przed scenariuszem, w którym zdalny b b nad b b b w sieci

i b - zrobi ona rzeczy dla systemu plików. Q b - gdy b strona wykorzystuje b c w Apache do b kontroli nad serwerem web, profil AppArmor Apache wykonanie akcji, która jest niebezpieczna.

W przypadku ssh, ssh zabrania root, wtedy polityka AppArmor e ssh nadanie b sysadmin, b mu tylko uprawnienia b i do /

wbudowane w programy, na b 'at' nie jest w stanie b z /etc/at.allow running as a system_u user. Z bitem setuid ustawionym na wykonywalny, b go jako inny - ale zachowuje oryginalny kontekst SELinux.

"Domyślnie użytkownicy Linuksa w domenach guest_t i xguest_t nie mogą wykonywać aplikacji w swoich katalogach domowych lub katalogu /tmp/, uniemożliwiając im wykonywanie aplikacji, które dziedziczą uprawnienia użytkowników, w katalogach, do których mają dostęp przy zapisywaniu. Pomaga to zapobiec modyfikowaniu plików użytkowników przez uszkodzone lub złośliwe aplikacje."[1]

W SELinux maksymalistyczne, czyli zaimplementowano b b MAC i RBAC. [b on zaadaptowany jako b instalowane w dystrybucjach, których - czyli CentOS 7.6 i Fedora 29. Konfiguracja i c b SELinux skomplikowane, b pomimo tego faktu, jego wykorzystanie w systemach systematycznie - b b w b o wymaganiach c b danych. Ob b b - SELinux jest b standardowym elementem systemu Android. Pomimo tego, definiowanie polityki w przypadku SELinux jest szczególnie skomplikowane, b w celu zabezpieczenia demona sieciowego polityka powinna b wszystkie obiekty, do których ma on - coraz b b w internecie wiele uogólnionych konfiguracji, a dystrybucji wyposa w SELinux posiada konfiguracje - które b b b b b i b do potrzeb danej instalacji. Na stronie *seedit.sourceforge.net* znajduje rozbudowany edytor konfiguracji, który znacznie upraszcza definiowanie polityki SELinux. Jednak zalecam - b na stronie widnieje informacja: *Ten projekt nie jest obecnie utrzymywany. Ta strona i kod istnieją tylko w celach informacyjnych.* Na nie brakuje dokumentacji i z lepszych jest ta b b na stronie Red Hat[2].

H b konfiguracja SELinux znajduje w pliku /etc/selinux/config. Dwa wiersze szczególnie istotne, a mianowicie:

---

[1] *https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/selinux_users_and_administrators_guide/sect-security-enhanced_linux-targeted_policy-confined_and_unconfined_users*

[2] *https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/5/html/deployment_guide/rhlcommon-chapter-0017*

Pierwszy parametr przyjmuje z trzech b ; enforcing, permissive lub disabled. Opcja enforcing wymusza b b b polityki i blokuje próby nieautoryzowanego / Permissive pozwala na naruszanie polityki, lecz zapisuje próby tego typu za syslog, co jest b szczególnie, gdy testowana jest konfiguracja serwera i rozwijana polityka SELinux. Ostatni parametr b SELinux. Parametr targeted jest w dystrybucjach z rodziny Red Hat. Definiuje on dodatkowe zabezpieczenie dla kilku demonów, które b chronione, lecz nie ingeruje to w b systemu.

Rozwijanie b polityk b b za b b audit2allow, które tworzy definicje polityk na podstawie dzienników b / Problem w tym przypadku polega na tym, zezwala na c b systemu tak, by jej naruszenia b zarejestrowane, ale nie egzekwowane, a b testuje system i buduje b b na b b b w oparciu o to, co podsystem c / Niestety, tego rodzaju nie jest w stanie b b b b c b wszystkich kodu, wygenerowane automatycznie profile nie c idealne.

1.2.5. Kontrola antywirusowa

W mojej pracy postanowi b b ClamAV i b - w jaki sposób b b z agentem Postfix w formie tzw. miltera, czyli filtra poczty (ang. *mail filter*). Program ten stanowi otwarty silnik antywirusowy, który w mierze przypomina b b takich firm jak Symantec czy McAfee. S b jednak polega na tym, w do produktów wspomnianych firm oprogramowanie i aktualizacje sygnatur w programie ClamAV c b / Program ClamAV wykorzystuje specjalne zwane sygnaturami do skanowania poczty pod danych b kod wirusa. L b b sygnatura zawiera informacje danego wirusa, np. znaków charakterystyczny dla tego wirusa, który pozwala na jego wykrycie.

1.2.5.1. ClamAV

ClamAV to zestaw b antywirusowych, które przeznaczone dla systemów uniksowych. L odgrywa tutaj potrzeba aktualizacji zarówno kodu jak i baz sygnatur wirusów. Program ten jest rozwijany przez b kilkunastu developerów i na licencji GNU GPL v2. ClamAV stosuje b b KISS (ang. *Keep it Simple, Single*). Dlatego

w wachlarzu programów dostarczanych w pakiecie b proste w wyspecjalizowane programy, które b b zc b z systemy b /

Clamscan jest prostym b b skanowanie plików oraz katalogów c z linii / Wystarczy b b poleceniem b pliku lub katalogu, który powinien b przeskanowany.

Clamd to b- która b b zaprojektowana do b b - w których istotna jest b / Program posiada c wielow - czemu jest w stanie b dodatkowe procesory w systemach SMP. V b ona b efektywne wykorzystanie baz sygnatur, które b b podczas startu oraz po wykryciu nowej wersji, a b przez wszystkie /

Freshclam to program b b proces aktualizacji baz sygnatur wirusów. Posiada on szereg opcji, które b b na uruchomienie go na b , w tle jako / Potrafi on b b z serwerami proxy, b uruchomienie programów w b od zdarzenia (aktualizacja bazy sygnatur, c - wykrycie nowej wersji oprogramowania).

1.2.6. Monitorowanie dzienników systemowych

K ! ! b b ! b b b bnie plików dzienników ! ! ! [b b ! ! b ! ! ! b b ! ! ! b b rozmaitych c ! b ! ! b K ! b b b nie ! ! ! c! ! ! ! ! b b ! ! b ! c ! wart ! ! ! b ! ! ! b ! X ! M ! ! ! ! rejestrowania informacji w jednym miejscu. P ! ! ! ! ! b b ! b ! b ! b ! b ! ! ! ! operacyjnym. Po zainstalowaniu systemu operacyjnego syslog, który jest konfigurowany w pliku konfiguracyjnym /etc/rsyslog.conf. jest od razu aktywny ! b ! ! !;

1.2.6.1. Dzienniki zdarzeń

W sytuacji, gdy nieprzewidzianego dzieje z b b lub - zawsze warto zb do dziennika systemowego lub dziennika b/ Administrator zazwyczaj zobligowany jest tzw. o gwarantowanym poziomie b b SLA (ang. *Service Level Agreement*), aby jak najszybciej ponownie u b

- jednak zajrzenie do dzienników b w poszukiwaniu przyczyny problemu pomaga zapobiec powtórzeniu nieprzyjemnej sytuacji. K sam w sobie demon dziennika b nie odpowiada, administrator jest w stanie b bufor dziennika za polecenia dmesg.

Linux wykonuje wiele procesów, które systemowe zasoby. Procesy tworzone przez system i serwery / Informacje o ich b b - przekazywane przez komunikaty, b w dziennikach b - które administrator powinien b b b /

Dzienniki b c w pracy b administratora. J oraz logowanych informacji jest ogromna. W systemie Linux zdarzenia przetrzymywane w plikach tekstowych, co dodatkowo utrudnia ich b b / J jednak b b- które b b b dzienników, np. GoAccess, który b b b logów serwera Apache.

Dzienniki b w systemie Linux to zarejestrowane zdarzenia systemu operacyjnego, aplikacji i - które b zgodnie z czasu. Przechowywane w postaci plików tekstowych, zazwyczaj w katalogu /var/log. Folder ten zawiera b c plików z informacjami o b aplikacji oraz katalogi dla szczeg dzienników b wybranych aplikacji. Ob b b plik z dziennikami b - jedno z (w b czy plik jest skompresowany lub nie):

K c b dzienniki b w trybie rzeczywistym, b b polecenie tail -f /var/log/nazwa_pliku_dziennika. Natomiast wyszukiwanie w plikach zrealizujemy ;

Logi b b b b w czasie rzeczywistym za b b;

L b dziennik b zawiera b - b hosta, b aplikacji lub - b lub komunikat. Dzienniki b b rotacji zgodnie z ustawieniami w pliku konfiguracyjnym /etc/logrotate.conf. Definiujemy w nim, z b c tworzone pliki z dziennikami b oraz jak c przechowywane. Q dyskowa systemów z b nie pozwala b na przechowywanie dzienników b - a przeszukiwanie takich plików nie jest ani

szybkie, ani elastyczne. Tu z p specjalne analizatory takie jak np.: LogAnalyzer analizator dzienników przez b web, GoAccess - darmowy analizator dzienników b serwera WWW, do b b dzienników w terminalu: multitail, jako rozszerzenie tail, swatch, lnav, a b inne jak logsentry, epylog, fwlogwatch, czy logcheck, które po odpowiedniej konfiguracji b informacje na wskazany adres e-mail.

Dzienniki b zazwyczaj podzielone na wiele plików umieszczonych w katalogu /var/log. Tworzeniem wpisów dziennika b b ciej dwa demony: journald i rsyslogd. P kolejno b z nich.

Demon journald

Wraz z systemd wprowadzono nowy mechanizm tworzenia wpisów dziennika. Demon journald tworzy binarne pliki dzienników i c b wraz z b (r)syslog (lub b b */

Dzienniki tworzone przez demona journald funkcjami:

- dzienniki indeksowane, co b proces wyszukiwania danych;
- wykrywane jest manipulowanie wpisami dziennika i nie b w b sposób ich b <
- wpisy dziennika b b format, a poszczególne pola dobrze zdefiniowane;
- b journald gromadzi dodatkowe metadane dzienników dla b wpisu;
- demon journald c formaty eksportowe (np. JSON).

Demon rsyslogd

Aplikacje b dane do rsyslog w specjalnym formacie, który c przetwarzany przez tego demona. V b ta pobiera b wpisy dzienników i b na nich operacje, jak c b b je w pliku.

1.2.6.2. Analizowanie i korelowanie dzienników

Skoro system Linux daje nam do dyspozycji pliki dzienników to, co b z nimi b c @Dzienniki b b dwa zastosowania:

- b czasu b b w b b systemu,
- pomoc w przyczyny problemu z b b systemu.

Aby móc pierwsze zadanie, potrzebne jest b - które identyfikuje wpisy dziennika oraz poinformuje administratora o ich c / Proces ten

nazywa analizowaniem i korelowaniem dzienników b / W ten sposób b w b sposób b proces analizowania i korelowania danych w codziennej pracy administratora.

To, o czym b b b - to fakt, analiza i korelacja dwiema odmiennymi b / B b nazywa badanie elementów b oraz b nimi b b / Administratorzy wzorców b b b poszczególnych serwerów i w stanie problem znacznie szybciej, zautomatyzowany system / Jednak model ten ma dwie istotne wady. Pierwsza z nich polega na tym, administrator nie jest w stanie c w dwóch miejscach / Natomiast b jest to, rozmiary gromadzonych danych i b one w pewnym momencie tak - pojedyncza osoba nie jest w stanie ich b b b /

W tym momencie pojawia korelacja. Ob b b jako wykrywanie dzy danymi. Administrator konfiguruje b b- które b dane, program je i b tylko te, które c - a b b korelacja pozostawionych danych tak, aby b je c b b w logiczny i b sposób, co pozwala administratorowi b b b b /

Dobrze skonfigurowane i b b programy w stanie w sposób b danych generowany przez codzienne operacje serwerów. Co - one w stanie b b b poszczególnymi typami danych i albo b b je w b - albo b poszczególne elementy do analizy. E b jest dobór b b - które b b dane, co pozwoli b administratora o b b b - na które b b /

Pierwszy etap w tworzeniu takiego zautomatyzowanego systemu powinien b na umieszczeniu zebranych danych w odpowiednim miejscu. Ob wszystkich aplikacji i serwerów wraz z - gdzie zlokalizowane ich pliki dzienników. W b kroku b c b te informacje i b - o czym ma c informowany administrator. Ob krytycznych komunikatów, które istotne dla b pracy serwerów. Listy powinny b pogrupowane pod priorytetów w taki sposób, aby informacji c b b b na adres e-mail, niektóre z nich c b na ekranie,

a jeszcze inne b b zautomatyzowane procesy lub c b samodzielnie b problem np. poprzez ponowne uruchomienie /

Trzeci etap polega na zaimplementowaniu procesu analizowania i korelowania dzienników, a b na skonfigurowaniu b korelacji i zaprojektowaniu oczekiwanych reakcji. Ob ze b b b b - b na komunikat oraz wszelkie dodatkowe informacje, które b z komunikatem.

1.3. Bezpieczeństwo sieciowe

System SSH, to - który do zdalnego logowania i zabezpieczenia sieciowych w niezabezpieczonej sieci. N tego c zdalne wykonywanie - do - transfer plików, przekierowywanie portów, b w ruchu sieciowym oraz tunelowanie VPN. Jest to klient-serwer, który wykorzystuje b w celu uwierzytelniania oraz zapewnienia i b komunikacji dwoma hostami. *Został zaprojektowany z myślą o elastyczności algorytmicznej, co umożliwia aktualizowanie i wycofywanie wykorzystywanych przez niego protokołów kryptograficznych w miarę rozwoju branży.* [3]

Oprócz SSH mechanizmy c b powinny c implementowane na poziomie sieci. Podstawowym b c b sieci jest zapora sieciowa (ang. *firewall*), czyli - lub oprogramowanie c b pakietów do sieci i systemów. W tym rozdziale OpenSSH, b SSH na licencji open source, a b podstawy konfiguracji i b b zapory sieciowej oraz generowania kluczy RSA w celu zabezpieczenia zdalnego logowania.

1.3.1. Zabezpieczenie logowania sieciowego

Zabezpieczenie logowania sieciowego polega na zainstalowaniu i poprawnym skonfigurowaniu zapory pakiety, która ogranicza i rodzaj ruchu sieciowego, jaki do sieci przez c b (ang. *gateway*) z internetu (lub przez c b b sieciami w ramach organizacji) w oparciu o b pakietu. Pakiet posiada adres i docelowy, numery

[3] Evi Nemeth, Garth Snyder, Trent R. Hein, Ben Whaley, Dan Mackin, James Garnett, Fabrizio Branca, Adrian Mouat, Unix i Linux Przewodnik Administratora Systemów, Wydanie V, Gliwice 2018, HELION, s. 1046

portów oraz typ - który brama przepuszcza lub odrzuca, a w niektórych przypadkach zapisuje w dzienniku pakiety, które nie b zestawu / Programy pakiety dla dystrybucji Linux w postaci programów. Ob spotyka iptables, który jest praktycznie prawie w b dystrybucji. W dystrybucjach CentOS, Fedora, Red Hat zainstalowany jest firewalld. Natomiast w dystrybucjach z rodziny Debian b b b b ufw (ang. *uncomplicated firewall*), który jest tak b b b b na iptables, lecz pozwala b czas, b b do minimum tworzenie - które w iptables /

X zapór sieciowych wykorzystuje porty, które zdefiniowane w pliku /etc/services (lub odpowiedniku, b od dystrybucji systemu). Demony b b za te b do odpowiednich portów i na b od zdalnych hostów. X portów, na których b popularne to tzw. porty uprzywilejowane, co oznacza, b przypisane numery z zakresu od 1 do 1023. Porty te c b przez konto root lub przez odpowiednie systemu Linux. Porty od 1024 c b przez dowolne i nazywane portami nieuprzywilejowanymi. Filtrowanie pakietów specyficzne dla oparte jest na b - ruch z serwera powinien c akceptowany b od portu i hosta docelowego, natomiast ruch jest blokowany dla wszystkich i zezwala na ruch cy tylko na portach i dla docelowych adresów IP.

Zapora sieciowa nie powinna c jedynym rodzajem zabezpieczenia przed b b z sieci. Jest to tylko jeden z elementów b - dopracowanej strategii c b/ Administrator nie powinien b innych b c b/ K tak - zapory sieciowej na c sieci c negatywny. L b serwer w sieci firmowej, czy korporacyjnej powinien c odpowiednio zabezpieczony, zaktualizowany, wzmocniony i monitorowany za odpowiednich b takich jak: Nessus, Nmap, Snort, Bro, czy OSSEC. W celu zmaksymalizowania zabezpieczenia logowania sieciowego na etapie projektowania c b sieci administrator powinien na wygodzie i b / Ostatecznie to czujn i administratora decyduje o c sieci, a nie profesjonalny zapory sieciowej.

1.3.1.1. Zdalny dostęp

W wielu przypadkach b za b zdalnie do Linuksa. Jest to szczególnie istotne, gdy mamy do dyspozycji dystrybucje Linuksa, które funkcje serwerowe w centrach danych lub regionach geograficznych, ewentualnie schowane w szafie serwerowej lub innym w racku. D takie serwery nie b nawet ekranów ani klawiatur, a do nich b b jedynie z poziomu sieci. W Linux bardzo prosto b b b zdalne z serwerami, co pozwala administratorowi na administrowanie i b b nimi. Istnieje wiele sposobów uzyskiwania zdalnego - których b b pulpitu VNC (ang. *Virtual Network Computing* przetwarzanie wirtualnej sieci), b do b z komputerami b b w systemie Windows RDP (ang. *Remote Desktop Protocol* zdalnego pulpitu) czy bardzo popularny SSH (ang. *Secure Shell* bezpieczna b*/ Na tym ostatnim protokole moj b - b jest on b wykorzystywany do zenia zdalnego z serwerami.

1.3.1.2. Korzystanie z protokołu SSH

SSH jest b b i bc b na wiele sposobów, b jego przeznaczeniem jest zdalna administracja serwerami. Q SSH b poprzez sieci TCP/IP (ang. *Transmission Control Protocol/Internet Protocol* kontroli b 0 internetowy) w modelu klient-serwer. Komputer, z którego administrator, klienta. Natomiast komputer, z którym b puje serwera, akceptuje ie i b b nim.

Q b za SSH szyfrowane i b b metody uwierzytelniania b b- lub klucza publicznego. By móc zdalne - administrator musi b adres IP lub b serwera, do którego chce b / Ob administrator inicjuje po stronie klienta, który komunikuje z serwerem poprzez port 22 przy TCP/IP) b numer portu w pliku /etc/ssh/sshd_config, co jest zalecanym b */ Po b b b serwer b c o podanie nazwy b i b c b. Gdy wprowadzone dane b - klient b zdalne z serwerem.

1.3.1.3. Konfigurowanie bezpiecznego połączenia SSH

Aby móc b b z serwerem poprzez SSH wystarczy terminala (w przypadku systemów Unix/Linux) lub odpowiedniego klienta (np. Putty w Microsoft Windows). X dystrybucji c b na Linuksie lub Uniksie zawiera wbudowany SSH oraz ssh. Aby z niej b b b b b oraz adres IP serwera lub jego b (przedzielone znakiem @), z którym administrator zamierza b b - co b zaprezentowane na listingu 1.

Listing 1 *Połączenie SSH*

lub

W listingu 1 b z serwerem sysadmin.info.pl jako deb_usr. Serwer prosi o podanie b b/ Po wprowadzeniu b b b zostaniemy zalogowani do wiersza serwera.

Podczas pierwszego b z danym serwerem istnieje akceptacji klucza RSA, który jest wygenerowany przez serwer SSH, z którym b / Po jego zaakceptowaniu jest on zapisywany wraz z b serwera w pliku known_hosts. Podczas b kolejnego b z tym serwerem SSH sprawdza przydzielony klucz pod wszelkich modyfikacji. K wykryje on b b - poprosi o oczyszczenie klucza przed b b b i odrzuci / W ten sposób administrator b - czy c b b w zdalne .

1.3.1.4. Konfiguracja i wykorzystanie kluczy RSA do połączenia SSH

X b SSH jedynie do b z serwerem z poziomu klienta w celu wprowadzania zmian w konfiguracji serwera lub instalacji oprogramowania. W tym podrozdziale b b SSH. X b uwierzytelnianie za kluczy.

Gdy jako administrator zdalnie do serwera przez SSH, b za b razem poproszony o podanie b b/ Nie ma problemu, robi to raz dziennie, jednak w ten sposób z serwerami, okazuje - jest to b proces, b b gdy korzystam z - skomplikowanych b /

Aby b sobie b - warto, b z uwierzytelniania za klucza, które b SSH. Wystarczy b b kluczy prywatny i publiczny, a b b klucz publiczny na serwery, z którymi potem c b przy jego pomocy. Po b b komunikacji zdalny serwer dokona sprawdzenia, czy b przeze mnie klucz prywatny stanowi b wspólnego klucza publicznego. K tak jest, proces uwierzytelniania zostaje b powodzeniem. Warto b na fakt, klucze prywatne i publiczne do uwierzytelniania administratora, natomiast szyfrowanie samego b jest gwarantowane przez klucze serwera SSH generowane w trakcie instalowania /

Bardzo b jest b b do klucza prywatnego, b bez niego b b osoba, która uzyska do tego klucza, c b b b (bez podawania b b* do b serwera b klucz publiczny.

Po otrzymaniu pary kluczy jest b jej b publicznej do zdalnego komputera. Aby administrator b z klucza publicznego, musi go b w pliku authorized_keys katalogu umieszczonego w folderze domowym. N samodzielnie b b tego klucza albo b w tym celu nar ssh-copy-id.

1.4. Bezpieczeństwo serwera web

1.4.1. Apache

J sposoby konfiguracji serwera Apache. Jeszcze do niedawna wykorzystywano HTTP, który jest jeszcze b - lecz b nowoczesnym standardom i b c b o c jako administrator b c b o c HTTPS (który chroni b http za TLS, znanego jako SSL ang. *Secure Socket* Layer) na swoim serwerze. X nie c HTTPS w witrynach internetowych z wielu istotnych powodów jest b elementem ich hartowania. Pierwszy i b b powód, to szyfrowanie ruchu klientem a serwerem. Jest to b o tyle, b jest podstawowe uwierzytelnianie HTTP np. podczas logowania do witryny internetowej banku, lub witryny opartej o wybrany system CMS, to b napastnikowi b komunikacji i zobaczenie b b/ Drugim

powodem - nawet b jest to, stosowaniu HTTPS strony - b autentyczny serwer, a nie c - która przypomina oryginalny serwis oraz, b b komunikacja ich b b WWW a serwerem jest zabezpieczona przed atakami Man in the Middle. W tego rodzaju ataku napastnik udaje, jest serwerem, przechwytuje zaszyfrowany ruch, odszyfrowuje go, a b ponownie go szyfruje i b do rzeczywistego serwera. Dodatkowo TLS b b jako mechanizm uwierzytelniania serwerem i klientem.

Aby taka konfiguracja TLS b b b - trzeba b b certyfikat TLS z certyfikatów (CA). Jest wiele i firm CA, w których b b certyfikat. W certyfikat b b b u rejestratora, u którego b b zakupiona nazwa domeny, lub b z c b / X c b b i b b w certyfikat od M Encrypt, który dostaje na 90 dni z b/

Jednym z dobrych - które b TLS dla - w tym Apache, jest strona wiki *Server Side TLS* firmy Mozilla, b pod adresem https://wiki.mozilla.org/Security/Server_Side_TLS. [b na niej interaktywne sekcje, które b b c b b bezpieczne konfiguracje serwisów WWW na podstawie kilku profili.

- Modern: b tylko nowoczesnych i bezpiecznych zestawów szyfrów i b - co oznacza, e witryna c b w wielu starszych wersjach b /
- Old: b b konfiguracja TLS z wykorzystaniem starszych zestawów szyfrów, co zapewnia b b wstecz z b b /
- Intermediate: dobre nowoczesnych szyfrów w profilu Modern z z b b - z niektórymi starszymi, ale popularnymi.

W prostej konfiguracji HTTPS wykorzystywane ustawienia zestawu szyfrów dla serwera. Zatem wszystko, co jest potrzebne, to lokalizacja certyfikatu i klucza prywatnego witryny. P trzeba b b o tym, certyfikat powinien c publiczny, natomiast klucz prywatny powinien c niejawny i do odczytu i zapisu dla b root (chmod 600). Konfiguracja c HTTPS oraz wymuszanie przekierowania ruchu z HTTP na HTTPS b opisane w praktycznej.

Istnieje sposób, aby b zabezpieczenia witryny za HTTPS, który polega na przeprowadzeniu ataku degradacji / Polega to na tym, napastnik zajmuje miejsce serwerem WWW a klientem i informuje klienta, HTTPS nie jest / W takim przypadku klient prawdopodobnie skorzysta z wersji HTTP witryny, czemu napastnik c niezaszyfrowany ruch klientem a serwerem. Nawet, gdy administrator serwera zadba o b przekierowania 302 z HTTP na HTTPS, to napastnik to w b sposób c / Problem zastosowanie HSTS (ang. *HTTP Strict Transport Security*). E niemu serwer Apache b do klientów specjalny b - który informuje ich, w komunikacji z serwerem powinni b z HTTPS. K administrator serwera Apache zastosuje HSTS, a napastnik podejmie c przeprowadzenia ataku degradacji - to b b c b b zbuforowany b z poprzedniej wizyty w witrynie i do klienta komunikat o c / D b stosowanie HSTS wydaje skomplikowane, dodanie jego c do witryny HTTPS jest bardzo proste. Wystarczy b jeden wiersz na konfiguracji HTTPS. W przypadku serwera Apache ten wiersz b b ;

Maksymalny czas (w sekundach) przechowywania b b w b w tym b ustawiony jest na b 15 768 000, czyli / O b jeszcze c b przy pomocy polecenia i b b serwer Apache.

W instrukcji b b b opisana jest instalacja WAF (ang. *Web Application Firewall*). Zapora WAF analogicznie jak zapora tradycyjna w tym sensie, jest zdolna do przechwytywania i blokowania ruchu na podstawie - jednak w do zapór tradycyjnych, które c pod b tylko i docelowe adresy IP oraz porty, WAF sprawdza b b b webowych b do serwera WWW i c b potencjalnie niebezpieczne b b webowe, zanim do serwera WWW i b przez niego przetworzone. W praktycznej b , w jaki sposób b b b b i b ModSecurity najpopularniejszy WAF dla serwerów Apache i Nginx. Mimo tego, ModSecurity b b zarówno z Apache, jak i Nginx, to pierwotnie b zaprojektowany dla serwera Apache i jest stosowany z nim o wiele / W z tym znacznie b ModSecurity z Apache Nginx. Q b Nginx

jeszcze nie c b b - ModSecurity wymaga kompilacji aplikacji Nginx, w z tym c b b b Mod Security na serwerze Apache. *„Serwer Apache obecnie zawiera do wyboru trzy moduły przetwarzania wieloprocesorowego (ang. multi-processing module — MDM): przedwstępny (ang. prefork), roboczy (ang. worker) i zdarzeniowy (ang. event).* [4]

1.4.2. PHP

Wiele aplikacji internetowych jest napisanych w PHP skryptowym, które b trzon witryn sieciowych na b - w tym popularnego systemu b b b (ang. *Content Management System* CMS) WordPress. Ponad 60% stron zbudowanych na bazie CMS b WordPress.[5] Z tego b na WordPress na serwerze web.

Po b b b strony, która jest napisana w PHP serwer Apache przetwarza kod i b wynik w b / Aby móc samodzielnie b tego typu aplikacje na serwerze, w/w serwer musi c w stanie ro i b kod PHP. Instrukcje zapisane w PHP powinny c wykonywane w sposób. Trzeba b do silnika Apache c b PHP i MPM (mpm_prefork), jak b b ze c b- a b PHP nie jest bezpieczne, wykorzystam procesów FastGGI do b b serwera Apache ze PHP. V b FastCGI jest w tej chwili jedynym sposobem na posiadanie bezpiecznego serwera WWW. Korzystanie z mod_php z punktu widzenia c b nie jest zalecane, a odchodzi od tego b b- b ten b b w serwera WWW i ma do wszystkich jego struktur danych, w tym do tablicy procesów dzieci. C w PHP b b do przeprowadzenia ataku DoS (ang. *Denial of Service*) na serwer Apache, a nawet na b serwer - proces b b za b b !)b !*spawn*) procesów pomocniczych b b na prawach roota, bc wszystkie procesy w systemie.

W mojej pracy b serwer baz danych MariaDB, - aby b z niego aplikacje internetowe, b jego c w PHP. Ponadto b b c powszechnie stosowanej biblioteki graficznej GD

[4] Dennis Matotek, James Turnbull, Peter Lieverdink, *Profesjonalne administrowanie systemem*, Wydanie II, Gliwice 2018, HELION, s. 454

[5] *https://w3techs.com/technologies/overview/content_management/all*

) do przetwarzania i modyfikowania plików obrazów), biblioteki konwersji znaków mbstring) b b c kodowania wielobajtowych b znaków), a b pocztowego IMAP (uaktywnia funkcje pocztowych IMAP i POP3). E temu ostatniemu c dzie b b b b i b aplikacje pocztowe w WordPress c b na PHP.

1.4.3. MariaDB

Gdy mowa jest o serwerze WWW (ang. *web services*) z b obecnie konfiguracji internetowej b przez serwer WWW jest wspomniany model LAMP. Maria DB stanowi c b bazy danych MySQL. Wiele b MySQL jest b w bazie danych MariaDB, natomiast zmienne konfiguracyjne i identyczne, co pozwala na b korzystanie naprzemiennie z obydwu typów serwera. Serwer MariaDB b stworzony, b twórców technologii MySQL niewykupiona przez b Oracle do tego, aby b b c b b i c b GNU GPL. Silnik MariaDB w dalszym wykorzystuje bazowy kod serwera MySQL i b obydwie bazy danych od siebie, to ich kolejne wersje ze c w pewien sposób b /

W MariaDB tak samo jak w MySQL administrator b b uprawnieniami za instrukcji GRANT. Przyjmuje ona szereg parametrów b b b- które b na danym komputerze oraz na obiekcie. Zgodnie z zasadami c b baz danych, administrator powinien konto b- który b operacje na pojedynczej bazie danych. W praktyce oznacza to, b b aplikacja b serwer baz danych MariaDB otrzymuje b konto b oraz b c b danych. K b kod PHP strony internetowej c b b c b do serwera bazodanowego, c b b jedynie dane w bazie danych wykorzystywanej przez /

1.5. Bezpieczeństwo serwera poczty

Jednym z b powodów b b b serwera linuksowego jest zapewnienia pocztowych, w tym odbierania i b b b e-mail, a b ich odzyskiwania za takich mechanizmów jak IMAP (ang.

Internet Message Access Protocol definiowany jako internetowy do b * czy POP3 (ang. *Post Office Protocol* definiowany jako pocztowych). W tym rozdziale aplikacje funkcje:

- Postfix serwer pocztowy, który bazuje na protokole SMTP (ang. *Simple Mail Transfer Protocol* prostym protokole transportowym poczty),
- Dovecot serwer, który wykorzystuje IMAP oraz POP3.

[b b podstawowe b b aplikacji przed spamem - SpamAssassin, wirusami - ClamAV oraz c b - w jaki sposób serwer przy pomocy Fail2ban.

1.5.1. Postfix

Istnieje kilka serwerów pocztowych w Linuksie na b Postfix, Exim i Sendmail. Zasady zabezpieczania zaprezentowane w tej pracy b b b do dowolnych serwerów pocztowych, lecz na potrzeby b konfiguracji c b Postfix w roli serwera poczty e-mail. Postfix b napisany przez eksperta ds. bc Pana Wietse Venema specjalnie z o c / Postfix b jest skonfigurowany z ustawieniami b b c / Konfiguracja serwera Postfix jest prosta i jednoznaczna, czemu w razie potrzeby b b - a b zamieszczone w rozdziale b do przeanalizowania.

J jest zrozumienie podstawowych kroków hartowania przez administratora, który b b b w konfiguracji, która zrujnuje c serwera poczty. Jednym z b b c administratora serwera pocztowego w zakresie c b jest niedopuszczenie do tego, aby serwer b wykorzystany w roli systemu open relay. Serwery pocztowe zasadniczo b dwie funkcje: c b b e-mail na adresy, za które odpowiedzialne oraz b komputerom w sieci b za swoim b (tzw. przekazywanie ang. *relaying*). Q b skonfigurowany serwer odbiera e-mail tylko dla tych domen, które b dodane w jego konfiguracji jako docelowe i powinien b b na wykorzystanie siebie w roli b b tylko uprawnionym komputerom. Natomiast open relay to taki serwer pocztowy, który przekazuje b e-mail w imieniu dowolnego nadawcy oraz do dowolnej domeny. Kiedy spamer zidentyfikuje serwer pocztowy jako open relay, b b - liczba b e-mail przetwarzanych przez serwer

znacznie / Spamer c bowiem b za takiego serwera tyle spamu, ile b- b serwer e-mail trafi na z wielu w internecie b serwerów spamu. X na ten temat znajduje w podrozdziale SpamAssassin.

H celem stosowania podstawowych z zakresu utwardzania jest ograniczenie grona - którzy b z wybranego serwera poczty e-mail.

1.5.2. Dovecot

Q b konfiguracja systemu Dovecot jako serwera POP/IMAP wykracza poza zakres niniejszego b / W instrukcji b b b utwardzonego serwera poczty b tworzenie wirtualnych kont w katalogu Maildir, który znajduje w katalogu domowym wraz z b tworzenia kont w bazie danych MariaDB. V b i b z SMTP, IMAP oraz POP3.

Dovecot jest serwerem poczty elektronicznej typu open source IMAP i POP3 dla systemów Linux/UNIX, napisanym z o c / Dovecot to b wybór zarówno dla b jak i instalacji. Jest szybki, prosty w konfiguracji, nie wymaga specjalnej administracji i b bardzo b b /

Dovecot jest jednym z najwydajniejszych serwerów IMAP, a c standardowe formaty mbox i Maildir. Skrzynki pocztowe transparentnie indeksowane, co daje Dovecot c b przy zachowaniu b c z b b do c skrzynek pocztowych. Uwierzytelnianie Dovecot jest niezwykle elastyczne i bogate w funkcje, c wiele baz danych i mechanizmów uwierzytelniania.

1.5.3. SpamAssassin

Jednym ze sposobów walki ze spamem i wirusami jest integracja SpamAssassin z agentem Postfix. Program ten bazuje na naiwnym klasyfikatorze Bayesa[6]. Filtrowanie bayesowskie polega na przewidywaniu b c b b b danego b- b b lub b innego elementu w b e-mail ze spamem. L b b b jest sprawdzana, czy jest legalna lub SpamAssassin ma b b - jako spam na podstawie b numerycznej, która jest wyliczona za szeregu modyfikowalnych testów lub / E b e-mail z wynikiem

[6] *http://obfusc.at/ed/bayes_filtering_pl.html*

b b 5,0 zostaje oznaczona, jako spam. X b jednak b w razie potrzeby w konfiguracji SpamAssassin. W b od wagi ona b b lub b b od ostatecznej oceny. Na b taka b b b parametr w b b e-mail i wynik operacji c pozytywny, do ostatecznej oceny zostanie dodane punktu. Filtry Bayesa w stanie wzorców na podstawie b - które na b i b je tren b w b spamu od b b / Informacje uzyskiwane w wyniku takiego treningu dodawane do bazy danych, a b wykorzystywane do przeprowadzania b analizy b / Program SpamAssassin b b na serwerze jako b- to znaczy, b e-mail do niego przekazywane, analizowane, a b zwracane z odpowiednim oznaczeniem dodanym do b b b / Aplikacja SpamAssassin dodaje b ;

- X-Spam-Checker-Version wersja programu SpamAssassin,
- X-Spam-Level ocena symbolizowana przez c gwiazdek,
- X-Spam-Flag widoczna jedynie wtedy, gdy b e-mail zostanie sklasyfikowana jako spam,
- X-Spam-Status stan spamu (Yes albo No), b wynik testów oraz lista testów,
- X-Spam-Report c b poszczególnych b wyniku,
- X-Spam-Prev-Subject poprzednia nazwa tematu b /

Pierwsze trzy b dodawane do wszystkich b e-mail. Q b wstawiane do b uznanych za spam.

1.5.4. Filtrowanie poczty za pomocą aplikacji Sieve

T b b- która do filtrowania b e-mail za programu Sieve jest prosta. Administrator b filtry globalne lub lokalne w katalogach domowych.

Program Sieve b kilku prostych i instrukcji warunkowych. Ich spis b b po wpisaniu polecenia:

M potrzebnych komend umieszcza na pliku (zazwyczaj ~/.dovecot.sieve), które powinny b umieszczone w katalogach Maildir /

1.5.5. Filtrowanie antywirusowe poczty – ClamAV

Administrator b ClamAV z agentem Postfix w formie tzw. miltera, czyli filtra poczty (ang. *mail filter*). Program ten w mierze przypomina produkty takich firm jak Symantec czy McAfee. W jednak do produktów wspomnianych firm, oprogramowanie i aktualizacje sygnatur w programie ClamAV c b / Agent Postfix pozwala na b b e-mail do filtra, a b jej ponowne zakolejkowanie. J dwa rodzaje milterów Postfix te, które c b na demonie smtpd oraz te, które nie b b SMTP. W instrukcji b b b b b b filtra c b na demonie smtpd.

Tak w uproszczeniu b proces.

W pierwszej administrator serwera musi b b b i b skaner ClamAV wraz z jego demonem, nazwanym clamd. Powinien b b b b i b b b b FreshClam, które automatycznie pobiera i instaluje sygnatury wirusów w programie ClamAV. O b zgodnie z musi b ClamAV z Postfix.

1.5.6. Zabezpieczenie serwera za pomocą Fail2ban

X serwerów Linuksa oferuje logowanie SSH przez Port 22 do celów zdalnej administracji. Port ten jest dobrze znanym portem, dlatego jest atakowany przez brutalne ataki / Fail2ban jest oprogramowaniem, które skanuje pliki dziennika w poszukiwaniu prób logowania z brutalnej w czasie rzeczywistym i zakazuje napastników za firewalld lub iptables. Fail2ban rozpoznaje b lub próby naruszenia c b do serwera w przez administratora czasie i blokuje adresy IP, które b oznaki ataków brutalnej lub ataków / Program ten b b w tle i stale skanuje pliki dziennika w poszukiwaniu nietypowych wzorców logowania i prób naruszenia c b/ Fail2ban jest w stanie bc b próby b b b b/ N b go b do banowania po trzech nieudanych próbach logowania podczas

uwierzytelniania klienta poczty. Opis instalacji i konfiguracji Fail2ban znajduje w instrukcji utwardzania serwera.

1.6. Bezpieczeństwo serwera plików

Serwerem plików (ang. *file server*) b w sieci komputerowej zasoby plikowe. V b plików c zrealizowane na dwa sposoby: za komunikacyjnego i sieciowego systemu plików. V b danych klientom Microsoft Windows lub Mac OS jest b o nazwie Samba, które / V b plików (ang. *file sharing*) nazywamy b dokumentów b /

W dzisiejszych czasach coraz rzadziej przechowuje swoje dokumenty na b komputerze i przekazuje je np. za poczty elektronicznej. Obecnie one gromadzone w jednym miejscu i pozwalamy pracownikom b do nich w kontrolowany i bezpieczny sposób. W ten sposób redukowane jest rozprzestrzenianie wersji jednego pliku - a ograniczanie i tworzenie kopii zapasowych dokumentów b znacznie b /

1.6.1. Samba

Samba jest oprogramowaniem b uruchomienie tak zwanego serwera plików, na systemie Linux. Jest ono kompatybilne z systemem Windows, dlatego jest bardzo powszechnie stosowane w firmach, uczelniach, instytucjach, b b b produkcyjnych, czy nawet bankach. Charakteryzuje bardzo c i bc pracy. W podrozdziale jak b b b i poprawnie b Tb c na b dystrybucji Linux Fedora. Samba b b zgodnie z tradycyjnym modelem klient-serwer: demon akceptuje b b od klientów sieciowych.

Q b b b b Samby CIFS (ang. *Common Internet Filesystem* powszechny internetowy system plików) i SMB (ang. *Server Message Block* blok komunikatu serwera), które c b komputerami b z systemu Windows, czemu program Samba jest kompatybilny z klientami i b domenowymi Microsoft Windows, co jest istotne w biurowym, gdzie powszechnie b przez pracowników.

Samba b b zgodnie z tradycyjnym modelem klient-serwer, który oparty jest na systemie b b generowanych przez klienta i odpowiedzi od serwera. X od tej zasady jest mechanizm tzw. oplock (ang. *opportunistic lock*), gdzie serwer generuje b - który informuje o zerwaniu b oplock-a (blokady).

Na dzisiejszy dwie c b wersje aplikacji Samba: 3.x i 4.x. Wybór odpowiedniej wersji b od tego, co chce administrator. Wersja 4.x b b Active Directory (AD), natomiast wersja 3.x bardziej przypomina NT 4. Ta druga c b z LDAP (ang. *Lightweight Directory Access Protocol* lekki do katalogu), z kolei w wersji 4.x ta funkcja jest eksperymentalna.

Samba pracuje w dwóch trybach:

1. Jako kontroler domeny NT. Samba od wersji 2.X potrafi b jako samodzielny kontroler domeny (ang. *domain controller*) lub do niej (ang. *domain member*). Samba 4 na c c systemy Windows do wersji Windows Server 2012 R2, jednak zanim serwer 2012 zostanie do kontrolera Samba AD, wymaga c serwera Windows 2008.
2. Jako serwer plików i drukarek w grupie roboczej (WORKGROUP) - to b i najprostszy sposób korzystania z serwera Samba. P Samba c dla klientów Windows tzw. logon domain, czyli logowanie do domeny, b na tym, na serwerze przechowywane profile - jest to wygodne i eleganckie b b b b b /

Pakiet Samba zawiera:

- serwer SMB b pliki i drukarki (w stylu Windows NT),
- serwer nazw (nameserver) NetBIOS zgodny ze b b w dokumentach RFC 100
- b b znakowe, które b b na uzyskanie do innych serwerów SMB z poziomu systemu Linux/Unix,
- programy pomocnicze i administracyjne.

2. Instalacja, konfiguracja i zabezpieczenie wybranej roli sieciowej w praktyce.

Ochrona serwerów stanowi spore wyzwanie. Zarówno aplikacje internetowe, pocztowe, serwisu do c plików jak i platformy serwerów, które je b b luk w zabezpieczeniach. Polityka ograniczania i konwencjonalne polityki kontroli - zapory ogniowe, a b systemy wykrywania i zapobiegania b b skuteczne w wykrywaniu ataków. Nie one jednak w stanie b c ataków typu b) b * do aplikacji internetowych. W niniejszej pracy przedstawiono praktycznie do b celów c b- identyfikacji b i ich eliminacji oraz zabezpieczenia kluczowych elementów serwera.

W tym rozdziale natomiast na zabezpieczaniu poszczególnych typów serwerów, ze na b potrzeby poszczególnych konfiguracji. T szerokiej gamy dystrybucji Linux, c b trzy dystrybucje: CentOS 7.6, Fedora 29 oraz Debian 9.8.0. Wykorzysta em Tripwire do monitorowania b ! b ! ! ! ! ! ! c b h, który b! b b b ! ! dystrybucji. Ob ! b ! b b b ster b b ! b b ! b ! ! ! /

W dystrybucji CentOS 7.6 oraz Fedora 29 SELinux jest zainstalowany ! ! b ! b b ! b /! W pliku y b! ! c ! c b ! c! /! Ob c ! b ! b b b b b b ! b setroubleshoot b ! polecenia:

V b c ! b b ! ! TFM b c b ! b /! H b ! b b b b ! TFM ! ! b ! b b ! ! b b ! ! ! c b b b b ! ! ! TFM /! O b ! b ! ! b b ! ! b ! ! ! b b ! powiadomienia o tych zdarzeniach. W b ! b ! ! b ! prezentuje powiadomienia ! b ! b b! c ! ! c ! ! b b /

T b ! b ! ! : /! V b b b c ! serwerach w trybie /! X b ! b ! ! b b ! c ! ! pomocy polecenia:

2.1. Serwer web

Serwer WWW ma b b c stron internetowych wymaganych przez komputery klienckie. Na potrzeby serwera web b c Debian 9.8.0, która posiada kernel oznaczony numerem 4.9.0.8.

W mojej pracy b b najbardziej b - b b pod b LAMP zestaw oprogramowania open source b b b dynamicznych stron WWW:

- Linux (system operacyjny)
- Apache (serwer www) wersja
- MariaDB (serwer bazy danych)
- PHP (parser b skryptowego PHP)

Pomimo b z tych elementów nie b stworzony z do b b b z b - to taki zestaw oprogramowania jest bardzo popularny ze na niski koszt i wszystkich komponentów, b one dla dystrybucji Linuksa.

Na potrzeby serwera web b laptop marki Toshiba model Satellite A210-19B, który posiada b b RAM DDR2 o 2048 MB, dysk twardy TOSHIBA MK2046GSX o 200GB, 5400 rpm Serial-ATA/300, procesor AMD Turion 64 X2 TL-60 2,0. BIOS marki Phoenix w wersji 2.0 b zabezpieczony b przed modyfikacjami. Dysk twardy b ustawiony jako pierwszy b /X b b b c b USB.

GRUB b zabezpieczony zgodnie z opisem w instrukcji b b b utwardzonego serwera.

2.1.1. Apache

Na potrzeby realizacji serwera web b zainstalowany Apache2 z dystrybucji Debian stretch w wersji 2.4.25 za polecenia:

Ob ustawiono uruchamianie podczas startu systemu oraz Apache przy pomocy ;

Po ponownym uruchomieniu serwera zaobserwowano za b b netstat, b on na porcie 443:

Instalacja certyfikatu TLS.

Zainstalowany b certyfikat TLS przy pomocy b b certbot, które b zainstalowane z dystrybucji Debian 9 przy pomocy polecenia:

Ob wygenerowane b klucze publiczny i prywatny jak ;

Klucze zapisane b w katalogu /etc/letsencrypt/live/sysadmin.info.pl i one do pliku wirtualnego hosta <VirtualHost *:443></VirtualHost>.

Włączenie obsługi HTTPS.

Pc b HTTPS b b dodana do wirtualnego hosta w Apache poprzez b b ;

Po restarcie serwera Apache przy pomocy polecenia , gdy przejdziemy pod adres https://sysadmin.info.pl w b jest widoczna ikona / Po na b informacje o certyfikacie. Do przetestowania witryny b b b b s_client z OpenSSL:

Certyfikat b sprawdzony na stronie https://www.digicert.com/help/ i potwierdzona b b w ten sposób b certyfikatu.

Przekierowanie http na https.

Ruch http jest przekierowany na https za mod_rewrite, który b poleceniem:

Przekierowanie jest realizowane poprzez wpis w pliku konfiguracyjnym wirtualnego hosta <VirtualHost *:80></VirtualHost>

wprowadzeniu tych zmian ponownie uruchomiono serwer WWW i sprawdzono, czy serwer jest b z popularnych b b przez /

2.1.2. PHP

PHP w wersji 7.3.3 b zainstalowane wraz z rozszerzeniami z dystrybucji Debian 9 za polecenia:

[b w skrócony sposób demona PHP-FPM wirtualnego serwera) opis b umieszczony w instrukcji b b b utwardzonego serwera).

Najpierw sprawdzam, czy FPM (ang. *FastCGI Process Manager*) b b/

W b kroku ustawiam, aby proces b wraz ze startem serwera i uruchamiam go . X b od starszych wersji PHP oraz profile mpm event i worker. . X b Mod PHP oraz profil mpm prefork poleceniami: i . S b serwer Apache: . W b kroku plik konfiguracyjny sysadmin.info.pl.conf mojej strony dla FPM w katalogu /etc/php/7.3/fpm/pool.d, który zaprezentowany jest ;

W pliku konfiguracyjnym wirtualnego hosta <VirtualHost *:80></VirtualHost> dodano ProxyPassMatch:

W pliku konfiguracyjnym wirtualnego hosta <VirtualHost *:443></VirtualHost> dodano SetHandler,

Te dwie dyrektywy b b - dopuszczane wszystkie pliki php, które b przekazywane demonowi PHP FPM.

Set Handler wymusza przetwarzanie przez FastCGI plików PHP, które wykorzystuje Mod Rewrite do przepisywania adresów, co jest jednym z wymogów instalacji Wordpress. Dyrektywa ProxyPassMatch zezwala na b b regularnego adres URL (ang. *Uniform Resource Locator* ujednolicony lokalizator zasobów), który jest przekazywany serwerowi / Podajemy parametry b b b tego serwera oraz katalogu, w którym dany program PHP ma b zainstalowany. Po skonfigurowaniu FastCGI i restarcie serwer Apache jest gotowy do korzystania z witryn internetowych oraz do c aplikacji napisanych w PHP.

2.1.3. AppArmor

W celu zapewnienia dodatkowej warstwy ochrony serwera web b b b decyzja o instalacji i AppArmor, jako jednego z b czynników bc b serwer przed b b .

AppArmor b zainstalowany z dystrybucji Debian 9 za polecenia:

Ob b zainstalowany starter oraz dodatkowe ;

Q b AppArmor jest b Linuksa, b go za b ;

Q polecenie katalog grub.d, w którym stworzono plik apparmor.cfg za polecenia:

Do pliku wklejono b b b ;

Zapisano zmiany i wykonano b b b grub za polecenia:

Ob zrestartowano serwer poleceniem:

Po ponownym uruchomieniu, sprawdzono, czy AppArmor jest przez uruchomienie komendy . Na ekranie b komunikat . W b b sprawdzone polityki AppArmor poleceniem:

Wynik w terminalu b zaprezentowany ;

X AppArmor jako podczas startu systemu poleceniem:

A b sprawdzono jej status poprzez:

V b jest aktywna po restarcie systemu. W celu ochrony serwera Apache zainstalowano profil poleceniem:

Ob profilu w trybie enforce:

W kolejnym kroku b Apache, który b za polecenia:

X AppArmor dla Apache i zrestartowano serwer poleceniami:

Polecenie b b b b b 47 profili, z czego 14 w trybie
i 33 w trybie . Dodatkowo lona b b informacja o tym, 36 procesów ma zdefiniowane profile, które b b w trybie . T to procesy Apache. Serwer b zabezpieczony przy pomocy AppArmor.
Q b logów jest zainstalowanemu auditd poleceniem:

2.1.4. Serwer baz danych – MariaDB

Na potrzeby serwera baz danych oraz serwera poczty b laptop marki eMachines model E725, który posiada b opera RAM DDR2 o 4096 MB, dysk twardy Western Digital WD2500BEVT o 250GB, 5400 rpm Serial-ATA/300, procesor Pentium Dual-Core T4200 2,0 GHz 64-bit. BIOS marki InsydeH2O w wersji 1.03 b zabezpieczony b przed modyfikacjami. Dysk twardy b ustawiony jako pierwszy b /

GRUB2 b zabezpieczony zgodnie z opisem w instrukcji b b b utwardzonego serwera.

Serwer baz danych ma b b c bazy danych wymaganej przez serwer web. W tym celu b b zainstalowana dystrybucja CentOS 7.6, która posiada kernel oznaczony numerem 3.10.0-957.10.1.el7.x86_64.

W tym paragrafie - jak b b serwer bazodanowy MariaDB w podstawowym zakresie. Natomiast, w jaki sposób bc b z serwerem WWW przy pomocy aplikacji openssl, która pozwala na tworzenie certyfikatów SSL (ang. *Secure Sockets Layer* warstwa bezpiecznych gniazd) lub TLS (ang. *Transport Layer Security* zabezpieczenie warstwy transportowej) oraz sposób instalacji systemu b b b WordPress, który c b ze na to, jest to jeden z b atakowanych systemów b b b (ang. *Content Management System* CMS), b w instrukcji b b b utwardzonego serwera MariaDB.
W dystrybucji CentOS b b b serwer MariaDB za b pakietów yum poleceniem:

Po instalacji serwera wprowadzono kilka podstawowych zmian w ustawieniach MariaDB. W dystrybucji CentOS serwer MariaDB b na wszystkich skonfigurowanych interfejsach sieciowych i adresach. W tym przypadku

baza danych znajduje na laptopie z systemem CentOS 7.6, natomiast serwer internetowy znajduje na laptopie z systemem Debian 9.8.0, w z tym ograniczono b b bazy danych do jednego interfejsu, jest to b praktyczne, które stosuje w dzisiejszym ze na c /
W pliku konfiguracyjnym wstawiono bind-address w sekcji [mysqld], która b b ; . Serwer bazodanowy jest w ten sposób poinformowany o tym, ma b b jedynie na adresie 150.10.0.11, ki czemu inne komputery nie w stanie b b p b z bb danych. Do pliku b dodane jeszcze b elementy, które pokazane na listingu 2.1.

Listing 2.1 *Plik /etc/my.cnf.d/server.cnf w dystrybucji CentOS*

Zaleca symbolicznych (symbolic-links=0), aby zapobiec b c b/
Urucho serwer MariaDB za polecenia:

Po uruchomieniu serwera istnieje zdefiniowania b b administratora i wyczyszczenia tabel za b b , które opisane jest w instrukcji b b b/ Po wprowadzeniu polecenia i konfiguracji serwer MariaDB jest bezpieczny. Nie c akceptowb b b przez zdalne komputery oraz - którzy nie b konta MariaDB. Aby b - c serwer MariaDB c uruchamiany w trakcie rozruchu systemu, komendy: .

Q z serwerem MariaDB jako administrator i konto b ; b b mu uprawnienia do bazy danych WordPress i tabel. Widoczne na listingu 2.2 polecenie tworzy b , który z serwerem MariaDB jedynie z poziomu komputera lokalnego za b b . T b kluczowe ! przydzieleniu b b ! ! wymagane przez WordPress. Natomiast skrót odpowiedzialny jest za wyznaczenie wszystkich tabel we wskazanej bazie danych o nazwie baza_wp.

Listing 2.2 *Przydzielanie uprawnień przy pomocy komendy GRANT*

'password';

[b b jest ograniczenie do tablic w pojedynczej bazie danych, b z b b oraz ustawienie b jak /

2.2. Serwer poczty

Jak b na potrzeby serwera poczty b laptop marki eMachines model E725, którego opis znajduje w paragrafie 2.4.1.

2.2.1. SELinux

Na serwerze poczty zb b b ! b ! b b ! ! b ! w SELinux poleceniem:

. Ob ! b ! ! 2244 ! b ! ! TTI ! ! TFM ;

. L b TFM ! D b BW b b w paragrafie 2.2.6.

2.2.2. Postfix

W dystrybucji CentOS 7.6 b b b Postfix za b pakietów yum poleceniem:

Pierwszym ograniczeniem, które b zastosowane c wybranie zakresu adresów IP, które b z serwera do przekazywania poczty. Jest to szczególnie istotne, gdy serwer jest do internetu. W konfiguracji ograniczono dozwolonych adresów IP tylko i do komputerów b do sieci lokalnej. M zaufanych sieci serwera Postfix ustawiono przy pomocy parametru w pliku /etc/postfix/main.cf.

X b tego parametru ma b rozdzielonej przecinkami listy podsieci. Zb c b o to, aby ta b b b ustawiona co najmniej na localhost (127.0.0.0/8) tak, aby b e-mail c b z serwera poczty. Oprócz tego b b na co najmniej b /Ob b b jednak podczas dodawania do tej listy adresów IP b z internetu. K haker c nad takim hostem, to c serwera pocztowego do przekazywania spamu.

Kolejnym b krokiem, który ma zapobiec temu, aby serwer Postfix b serwerem open relay, c zdefiniowanie konkretnych b przekazywania przy pomocy polecenia . Q ! ! b b ! ! ! ustawione r ! ! b b !c /!N ! b ! ! polcenia:

O b ! b ! ! b ! ! ! b b;

Q ! TN UQ b ! b ! ! ! ! . E ! ! b ! ! b b ! ! z ! ! ! ustawienie , ! b ! ! ! ! ! b ! ! . [b ! ! b ! ! ! ! b ! ! b ! b ! b ! ! b ! ! b /

O b w etapie rozszerzono o kolejne elementy. Q b wszystkich bc b w instrukcji b b b utwardzonego serwera.

Q b dodatkowo bc ustawienia serwera Postfix. W tym celu b pewne opcje do pliku main.cf. X z nich do odrzucania b e-mail, które nie zgodne ze standardem SMTP RFC, na b b z b adresów pocztowych. Przede wszystkim b b b listy b - b podczas definiowania procesu uwierzytelniania. D z tych b b - wobec tego na tych, które nie b wymienione / E komendzie postconf z b -e jest b dyrektywa do pliku main.cf. E b b opcje:

Dyrektywa odpowiedzialna jest za odrzucanie b z serwerem poczty, w sytuacji, gdy nie zawiera on rekordów A i MX w systemie DNS. Natomiast opcja odpowiedzialna jest za b ! b ! ! b ! b bl N UB-! ! ! ! ! ! Postfix. K ! ! ! ! b go powitania FI MP! ! ! ! ! b -! Q ! b b ! ! ! b ! /! Q bl bl bl ! -! c ! ! ! ! ! b ! b ! ! / Opcjonalnie d b ustawienia do list og b nadawcy, odbiorcy i danych. Do pliku main.cf b !opcje w .

Parametr powoduje odrzucanie b e-mail przez Postfix, w których adres nadawcy ma b format. To znaczy, b przekazywana przez polecenie MAIL FROM musi b b o adresu e-mail, np. info@sysadmin.info.pl. Adres, na jaki serwer Postfix nie c c w

stanie - np. Info, czy info, nie zostanie zaakceptowany, b przez niego nadana zostanie odrzucona.

Opcja odpowiada za ignorowanie b od nadawcy, który nie ma zdefiniowanych rekordów A lub MX w systemie DNS. Taka sytuacja - gdy b b z b domen; jest to jedna z cech spamu.

Ustawienie jest odpowiedzialne za odrzucanie b - których nadawca nie ma zdefiniowanego adresu zwrotnego w swojej konfiguracji DNS.

Parametr powoduje odrzucenie b - które nie posiada b informacji o adresie klienta serwera poczty, z którego b b b b b /

E b b kolejne kryterium odrzucania do ustawienia .

Opcja sprawdza adres dbl.spamhaus.org pod klienta, jakim jest lista blokowanych domen (ang. *domain block list* DBL). S b to pomaga b spam na podstawie kilku elementów (polecenie HELO, IP/DNS, nadawca i adresat, itd.).

Ob dwie listy blokowania domen na komendzie HELO ( ) i nadawcy ( ).

Ograniczenie odrzuca b e-mail b b potokowaniem (ang. *pipelining*) bez sprawdzania, czy mechanizm ten jest c b / Jest to metoda, powszechnie spamerzy do rozprowadzania niechcianej poczty. E b b do dyrektywy , aby wychwytywanie spamerów b potokowania na etapie b b komendy DATA.

Na koniec b parametr, który nie jest b z listami b - lecz blokuje spamu.

Parametr b c polecenia VRFY b SMTP. Komenda VRFY b nadawcy b serwer poczty i - dany adres istnieje. Spamerzy b tej komendy do wyszukiwania adresów, a hakerom od czasu do czasu przydaje przed atakiem do zdobycia nazw / Po wprowadzeniu zmian b b demona Postfix. L zabezpieczenia jest zastosowanie popularnego b w postaci uwierzytelniania na podstawie nazwy b i b b/ W celu b sposobu, w jaki powinni c uwierzytelniani na serwerach SMTP, utworzono SASL. W przypadku Postfix SASL nie jest c b c / Zadanie uwierzytelniania jest realizowane za systemu Dovecot SASL, którego b b /

2.2.3. Dovecot

Instalacji Dovecot w dystrybucji CentOS 7.6 b ! b pakietów yum b! ! b:

Konfiguracja Dovecot b b! b b w taki sposób, aby b ! utworzone gniazdo UNIX, z którego serwer Postfix b , aby b ! ! z systemem Dovecot w przypadku, gdy zajdzie potrzeba przeprowadzenia uwierzytelniania b/ E b edycji pliku i b b b w sekcji :

E ! ! ! gniazdo , które b do b i grupy . W b kroku w pliku w konfiguracji systemu Dovecot b :

Po wprowadzeniu tych b zrestartowano system Dovecot:

Po restarcie b utworzony plik .

W b etapie po skonfigurowaniu systemu Dovecot trzeba b serwer Postfix o tym, z jakiego pliku gniazda UNIX ma b w celu przeprowadzenia uwierzytelniania za systemu Dovecot. E b ! b ! wiersza do pliku konfiguracyjnego Postfix:

Warto b na to, b na , uwierzytelnianie SASL za opcji oraz b , Postfix o tym, gdzie b plik gniazda UNIX, który / Ta konfiguracja jest dobra na - jednak pozostaje jeszcze kwestia b na serwerze Postfix c TLS, której b jeszcze bardziej b uwierzytelnianie SASL uwierzytelnianie za komunikacji jawnym tekstem szyfrowaniu za TLS. Aby to c - zmieniono ustawienie w b sposób:

Q nawet o krok dalej i wszystkie próby uwierzytelniania, nie realizowane za TLS:

Na koniec b b b w taki sposób, aby uwierzytelnionym przekazywanie b e-mail:

Po wprowadzeniu tych zmian ponownie serwer Postfix.

T b klienta poczty e-mail w taki sposób, aby podczas b b b e-mail c przeprowadzenie uwierzytelniania na serwerze Postfix.

Aby b SMTPS dla serwera pocztowego, trzeba b b certyfikat. W tym celu b polecenia:

Po wygenerowaniu certyfikatu b krokiem jest poinformowanie o nim serwera Postfix. E R N T JJC S ‡ Y •2’âá ¢„ •2 ñ)Y3€ ˆ S% 2 ˆ Ò ˆ •F ™ 2 Pf@ Z L G áYS(Dp tego za pliku konfiguracyjnego Postfix umieszczamy

M Encrypt podczas generowania pary kluczy ustawia SUPPORT G á 2‡&2„ . õ¿ ‡& ‡ Y¿

Po restarcie serwera Postfix jest on gotowy do tego, aby b TLS, zdalny serwer pocztowy c go c b (tak jest w przypadku produktów wielu dostawców pocztowych).

2.2.4. SpamAssassin

V modyfikacji jest instalacja i konfiguracja programu SpamAssassin. [b od zainstalowania potrzebnych pakietów. W dystrybucji CentOS 7.6 b b b pakiet SpamAssassin i b demona SpamAssassin do automatycznego uruchamiania w czasie rozruchu.

W momencie uruchomienia aplikacja SpamAssassin b demona spamd. T b systemowego, który c c b wspomnib za polecenia:

Za flagi -r wyznacza b systemowego (identyfikator UID jest mniejszy od b 1000), opcji -m tworzy katalog domowy, natomiast parametr -s definiuje / Q polecenie jest stosowane w dystrybucji CentOS. V b uruchamianie demona SpamAssassin podczas startu systemu przy b polecenia:

Wymieniona w mojej pracy dystrybucja CentOS 7.6 przechowuje pliki konfiguracyjne aplikacji SpamAssassin w katalogu /etc/mail/spamassassin. W pliku local.cf b b klasyfikowania b e-mail jako spamu (required_score) w b sposób:

E b edytycji pliku i b wg wzoru:

Ob b plik w dystrybucji CentOS, w którym zawarte opcje przekazywane demonowi (SPAMDOPTION). V tu konto b i - które c spamd.

Flagi -u i -g do b / Q b opcje do b b (-d), tworzenia plików preferencji b (-c), b liczby potomnych procesów (-m), a b wyznaczenia innego katalogu pomocy (-H) ta ostatnia przydaje /
W pliku /etc/sysconfig/spamass-milter b flagi:

E b edycji pliku /etc/sysconfig/spamass-milter-postfix i b dwa parametry tak, jak ;

Ob trzeba uruch demona spamd. V w tym celu komendy systemctl.

Najpierw b edycji pliku i b b b e-mail do programu SpamAssassin. [b w tym celu smtp.

X b do w/w pliku wiersz -o content_filter=spamassassin (flaga -o powinna c poprzedzona kilkoma spacjami, aby b b w ten sposób, mam do czynienia z b poprzedniego wiersza). Przy pomocy opcji
agenta Postfix, - aby wszystkie b e-mail dostarczane poprzez smtp c b do filtra SpamAssassin. W kolejnym kroku trzeba b ten filtr. W tym celu jego opis na pliku go w b sposób:

Tworzona jest w ten sposób w pliku master.cf nowa b typu unix (czyli gniazdo uniksowe), która innego demona serwera Postfix o nazwie pipe. T on do przekazywania b e-mail do polecenia. W kolejnym wierszu) b b b b * wyznaczam /

Ustalam b c - samo polecenie oraz jego argumenty. W polecenie spamc plik binarny z demonem SpamAssassin, b mu nasze b e-mail, a b wyniki. Q b komendzie spamc argument -e. Opcja ta musi c zdefiniowana jako ostatnia w wierszu / Wskazuje ona poleceniu spamc, co b c z b e-mail po jej przeskanowaniu. W tym przypadku przekazywana jest ona instrukcji , która zwraca agentowi Postfix b b b b do dostarczenia (program sendmail zawiera b symboliczne do pliku /usr/sbin/sendmail.postfix).

T b b ustawienia polecenia sendmail. Opcja -io do tego, aby b samotne kropki podczas skanowania b e-mail, b wia e-mail b b wiersze z kropkami, które nie b b b b / Parametr -f ${sender} gwarantuje, dane nadawcy b e-mail b przekazane agentowi Postfix, natomiast w ustawieniu ${recipient} zostaje jej adresat, przez co serwer Postfix wie, komu b b /

N jest komunikatów demona spamd poprzez dodanie flagi -D do opisanych opcji SpamAssassin. V b w ten sposób b znacznie informacji i b c b b mechanizmy wykonywane przez tego demona.

K program SpamAssassin uzna b e-mail za spam, do jej tematu zostanie b [SPAM] zgodnie z b b b w pliku . W tym przypadku b spam jest standardowo dostarczana do skrzynki pocztowej adresata. Zazwyczaj ludzie spam do osobnego folderu, b go i b / Niektóre osoby z góry b lub b tak oznaczone b - co czasem prowadzi do wykasowania istotnej poczty.

SpamAssassin nie jest nieomylny i c b sytuacje, gdy administrator serwera pocztowego ma do czynienia z b alarmem, czyli b b e-mail b oznaczona jako spam. Wraz z wykasowaniem spamu traci b / Przechowywanie spamu przez b czas w osobnym folderze b b na odzyskanie b b / Do dobrych praktyk b przeniesienie b oznaczonych jako spam do specjalnego folderu w katalogu Maildir, gdzie serwera poczty c mogli go na spokojnie / W tym celu b b b techniki wymienione

b do przenoszenia oznaczonych b / X tych metod takie jak:

- agenta LTMP (ang. *Local Mail Transfer Protocol* lokalny transportowy poczty), np. Dovecot,
- agentów MDA, takich jak procmail lub maildrop,
- 0 b b klienta pocztowego.

W mojej pracy b Dovecot do b b poczty od agenta MTA do katalogów domowych / Filtrowaniem b e-mail zajmie kompatybilna z serwerem Dovecot aplikacja Sieve[7]. Aby móc b z serwera Dovecot, b LMTP proces uruchamiany przez proces Dovecot, który uruchomiony jest b czas w trakcie b b b Dovecot. Jest to b b serwerem Dovecot a programami procmail i maildrop, które uruchamiane przez b b b b e-mail. Poza tym LMTP potrafi b b na osobnym serwerze, odczytuje gniazda uniksowe i TCP.

2.2.5. Filtrowanie poczty za pomocą aplikacji Sieve

Pierwszym etapem jest zainstalowanie dodatkowych pakietów, które b b b b Sieve. W przypadku dystrybucji CentOS komendy:

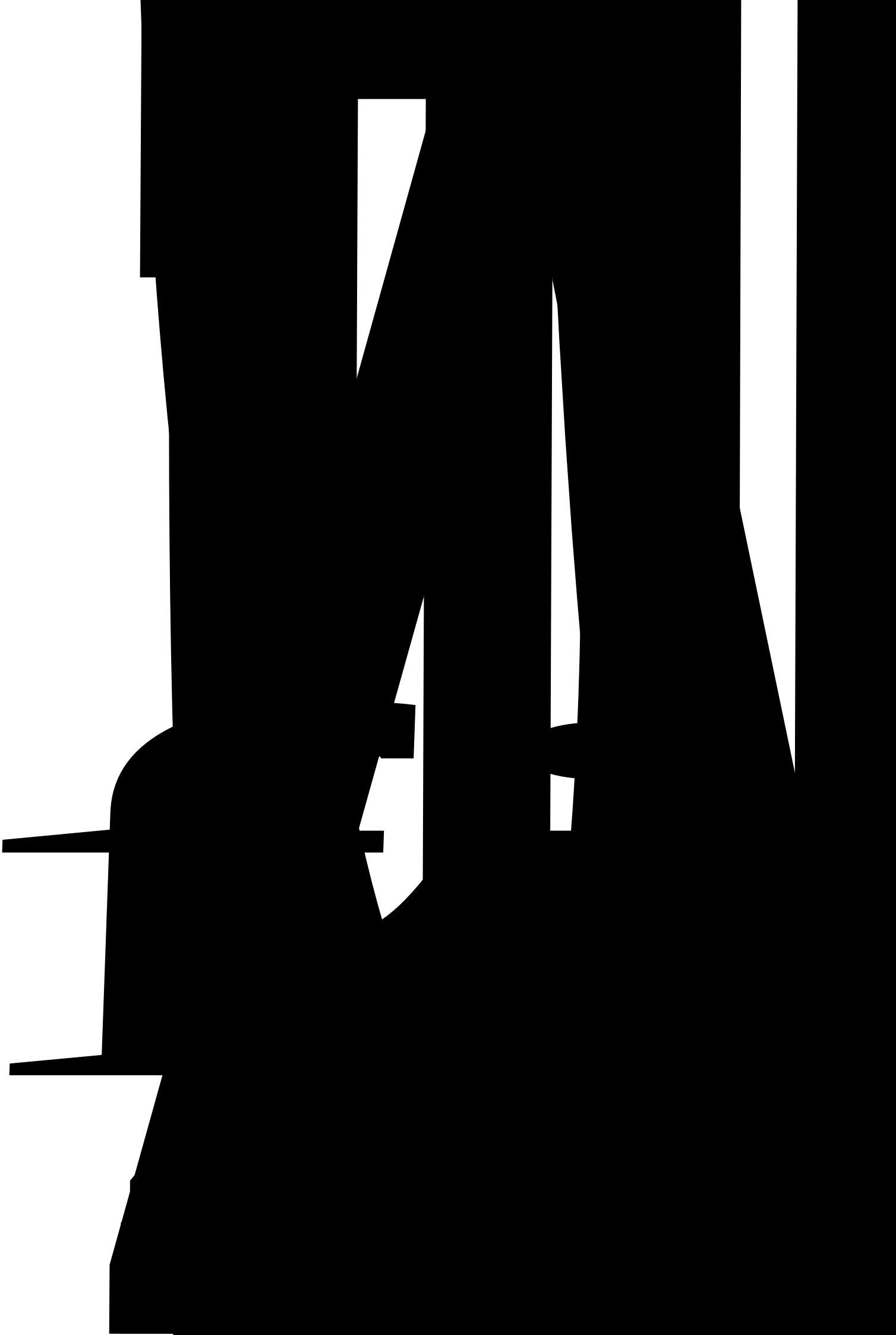
W pliku /etc/dovecot/dovecot.conf b wiersz, aby Dovecot b b b z LMTP.

Ob b plik :

W b kroku b do procesu Dovecot proces LMTP/gniazdo uniksowe, co a serwerowi Postfix b b / E b edycji pliku w sposób:

Na koniec b serwer Dovecot tak, aby nie b nazwy domeny z adresu e-mail podczas dostarczania poczty. Proces LMTP wydobywa b

[7] *http://sieve.info/*



Instalacja skanera ClamAV w dystrybucji CentOS na serwerze poczty

J b b ClamAV wykonano b polecenia:

Na koniec dokonano korekty zasady SELinux. Aby fragment kodu b b b - zainstalowano pakiet za polecenia:

W tym b wykorzystano plik docelowego wpisu do wygenerowania pliku pakietu zasad, a b wczytano go do mechanizmu SELinux.
Stworzony b plik w katalogu domowym

Wstawiono do niego b b ;

Pierwszy wiersz zawiera b i jego / Sekcja require przechowuje wymagane przez nas typy i klasy. Na umieszczono informacje b demonowi smtpd z gniazdami uniksowymi, takimi jak /run/clamav-milter/clamav-milter.socket, i zapisywanie w nich danych.

W b skompilowano pakiet zasad, które wczytane b do konfiguracji SELinux. Najpierw skompilowano plik zasad z komendami:

Wraz z poleceniem checkmodule stosowane b argumenty: -M b c bc Linuksa (ang. *Linux security modules* LSM), -m generuje plik binarny - natomiast -o definiuje b wynikowego pliku.
Utworzono pakiet zasad przy b komendy:

Stworzony b pakiet zasad, b y (-m) poleceniu semodule_package, po czym wynik operacji b zapisany (-o) do pliku clamav.write.pp.
N b teraz b ten do b SELinux. Wystarczy b ;

W ten sposób zainstalowano (-i) b b clamav-write.pp do bc SELinux. Czas ClamAV.
Aby móc b b program antywirusowy, najpierw pobrano c b wirusów poleceniem:

Po zainstalowaniu wszystkich potrzebnych pakietów aktywowano i uruchomiono demona ClamAV:

O b e clamav-milter i freshclamd) b b za aktualizowanie sygnatur wirusów):

Testowanie serwera Postfix z zainstalowanym skanerem ClamAV

Po uaktywnieniu miltera ClamAV musisz b - czy b e-mail analizowane pod c wirusów. V do tego celu programu swaks oraz stwórz plik eicar.txt. Plik eicar.txt zawiera fragment kodu, który powinien bb b b skaner ClamAV.

Q b ;

Wykonanie polecenia pozwoli b b b b /

X b ta zostanie najpierw odebrana i przetworzona przez agenta MTA, a b przekazana milterowi ClamAV, który c b ze skanerem, po czym, b od konfiguracji, b b do aplikacji SpamAssassin. Poczta zostanie przekazana admin@sysadmin.info.pl, i c b b b b jej b / W listingu zaprezentowane b otrzymanej b e-mail.

Q b ;

X b na listingu, do b e-mail b dodane b X-Virus-Scanned i X-Virus-Status. Skaner wirusa (Infected), b sy b z b w bazie danych. Gdyby wirus nie b wykryty, b X-Virus-Status b b c b Clean (czysta).

Filtrowanie zainfekowanej poczty

Podobnie jak w przypadku b b X-Spam-Status, jest b zawartej w b X-Virus-Status do innego traktowania b b b wykryty kod wirusa. Q b c one b do osobnego folderu nazwanego Virus. E b tego b przy pomocy b wtyczki Sieve podczas oddzielania spamu od b b e-mail. Wystarczy b fragment do pliku ~/.dovecot.sieve:

Nie b b zainfekowanych plików do / Powinny c one umieszczane na serwerze pocztowym w kwarantannie. O b w tym celu b parametr OnInfected Quarantine pliku clamav-milter.conf. X b ta b b zmodyfikowana - aby testowa b b b na / S b jednak c b tego typu b - aby b b ryzyko przypadkowego otwarcia zainfekowanego pliku.

2.2.7. Instalacja i konfiguracja Fail2ban

Q op - w jaki sposób b b b i skonfigurowb poprawnie b b Fail2ban, na wszystkich serwerach w mojej pracy.

Aby b b b Fail2Ban na CentOS 7.6, w pierwszej trzeba c b b b repozytorium EPEL (ang. *Extra Packages for Enterprise Linux*). EPEL

zawiera dodatkowe pakiety dla wszystkich wersji CentOS, jednym z tych dodatkowych pakietów jest Fail2Ban.

W b kroku b b b b zasady SELinux.

Po zainstalowaniu, c musieli b i b oprogramowanie za pliku konfiguracyjnego jail.local. Plik jail.local b plik jail.conf i jest b w celu zapewnienia c twa aktualizacji konfiguracji b/ Zrób pliku jail.conf i zapisz go pod b jail.local: zaktualizuj SELinux:

Otwórz plik jail.local do edycji w Vim za b polecenia.

Kod pliku b b z wielu linii kodów, które - aby zapobiec zablokowaniu jednego lub wielu adresów IP, b czas trwania bantime, itp. Typowy plik konfiguracyjny b zawiera b linie:

- IgnoreIP do ustawienia listy adresów IP, które nie c zakazane. Lista adresów IP powinna c podana z separatorem spacji. Ten parametr jest b do ustawienia osobistego adresu IP) istnieje do serwera ze b adresu IP).
- Parametr Bantime do ustawienia czasu trwania sekund, na które host ma b zbanowany.
- Findtime jest parametrem, który do sprawdzenia, czy host musi b zbanowany czy nie. Gdy host generuje maksimum w ostatnim findtime, jest on banowany.
- Maxretry jest parametrem b do ustawienia limitu liczby prób przez hosta, po przekroczeniu tego limitu, host jest banowany.

Dodawanie pliku więzienia (ang. *jail*), w celu ochrony SSH.

Utwórz nowy plik za edytora Vim.

Do pliku b b b wiersze kodu.

- Parametr enable jest ustawiony na b true, w celu zapewnienia ochrony, aby - jest ustawiony na false. Parametr filtra sprawdza plik konfiguracyjny sshd, b w /etc/fail2ban/filter.d/sshd.conf.
- Parametr action do wyprowadzenia adresu IP, który musi c zakazany za filtra w pliku /etc/fail2ban/action.d/firewallcmd-ipset.conf.
- Parametr port b na b - np. port=2244, jak to ma miejsce w tym przypadku. W przypadku korzystania z portu 22, nie ma potrzeby zmiany tego parametru.
- b logowania podaje - na której zapisany jest plik logu. Ten plik dziennika jest skanowany przez Fail2Ban.
- Maxretry do ustawienia maksymalnego limitu nieudanych wpisów logowania.
- Parametr Bantime do ustawienia czasu trwania sekund, na który host musi b zablokowany.

Uruchomienie usługi Fail2Ban

K jeszcze nie b zapory sieciowej CentOS, uruchom ;

Wykonaj plecenia, aby Fail2Ban na serwerze.

Śledzenie wpisów logowania

Q polecenie do sprawdzenia, które próby zalogowania do serwera przez post ssh nie /

Wykonanie komendy spowoduje listy nieudanych prób wprowadzenia b b z adresów IP. Format wyników c podobny do pokazanego ;

Sprawdzanie zbanowanych adresów IP przez Fail2Ban

Q polecenie do uzyskania listy zablokowanych adresów IP, które b rozpoznane jako b b brute force.

Sprawdzanie statusu Fail2Ban

V b komendy, aby b status plików jail w Fail2Ban:

Wynik powinien c podobny do tego:

Usunięcie zbanowanego adresu IP

W celu b adresu IP z zablokowanej listy, parametr IPADDRESS jest ustawiony na odpowiedni adres IP, który wymaga odbanowania. Nazwa "sshd" jest b b- w tym przypadku jest to "sshd", które b /Q polecenie pozwala adres IP.

Dodawanie własnego filtra w celu zwiększenia ochrony

Fail2ban b tworzenie b filtrów. Q krótki opis konfiguracji jednego z nich.

1. Ob ! do katalogu filter.d Fail2ban:

2. Utworz plik wordpress.conf i b do niego b regularne.

[b b i b plik.

3. Dodaj WordPress na pliku jail.local:

W tym celu zostanie ban i akcja e-mail. Inne akcje c zdefiniowane przez dodanie akcji = linia.

Zapisz i - a b uruchom ponownie Fail2ban poleceniem:

4. T b - czy Twój regex b b;

5. W celu ochrony poczty dodaj wykorzystaj mechanizm i utwórz pliki oraz w katalogu

6. Do pliku wstaw b ;

7. Do pliku postfix.auth.conf wstaw b ;

8. Do pliku /etc/fail2ban/jail.local dodaj wpisy

9. Zrestartuj fail2ban poleceniem:

2.3. Serwer plików

Na potrzeby serwera plików b laptop marki DELL model Inspiron 17 5767, który posiada b opera RAM DDR4 o 8192 MB, dysk twardy o 2 TB, z czego 1 TB b wydzielone dla potrzeb serwera plików, 5400 rpm, procesor Pentium Intel Core i7 7500-U 2 rdzenie po 2,7 GHz 64-bit. BIOS UEFI marki DELL w wersji 1.2.6 b zabezpieczony b przed modyfikacjami. Dysk twardy b ustawiony jako pierwszy b / X bootowanie z b USB.

GRUB2 b zabezpieczony zgodnie z opisem w instrukcji b b b utwardzonego serwera.

Serwer plików ma b b c b b plików i katalogów w sieci LAN oraz w razie potrzeby w Internecie. W tym celu b b zainstalowana dystrybucja Fedora 29, która posiada kernel oznaczony numerem 5.0.6-200.fc29.x86_64.

2.3.1. Samba

W mojej pracy b Samba w wersji 4.9.5, a b b SMB w wersji 3, b SMB 1 b wycofany ze c b/ Natomiast ze na to, SMBv3 jest c b w Windows 10 a b na fakt, Windows 7, w którym jest b SMBv2, traci wsparcie Microsoft, o jego /

W dystrybucji Fedora 29 b b b pakiet Samba i b demona Samba oraz NMB, aby c y automatycznie uruchamiane w czasie rozruchu serwera plików.

Nas Samba oraz NMB - Serwer nazw NetBIOS w celu b b klientom nazewnictwa IP w systemie NetBIOS:

[b b b b firewald. Do zapory b - która zezwala na b Samby:

T b SSH i demona sshd na porcie 50687 i odblo b port w zaporze:

[b b b b b do b b b portami i b w SELinux poleceniem:

Ob b port 50687 do zestawu dla SSH w SELinux:

Zbc logowanie SSH para kluczy RSA, logowanie dla root oraz za b b/

[b na b b serwera w trybie serwera plików. J b b oraz b bc Samba b w instrukcji b b b utwardzonego serwera.

Aspekty b z c - np. stosowanie Samby na serwerze na b do Internetu bez maskowania adresów IP jest niemal zaproszeniem dla hakerów. Administrator powinien b takich b i b z b - b b tam, gdzie chodzi o b dane.

2.4. Instrukcja wdrażania utwardzonego serwera (od etapu instalacji do chwili oddania do użytkowania).

Instalacja systemu

Instalacja systemu sprowadza do pobrania z obrazu systemu ze strony twórcy danej dystrybucji i nagranie obrazu na lub pendrive. W internecie jest bardzo

poradników na ten temat, które w sposób - w jaki sposób b / Ob pendrive do portu USB lub do b z b b systemu.

Podczas uruchomienia serwera wystarczy b klawisz F12 i c b odpowiednie - na którym znajduje nagrany obraz dystrybucji, trzeba b b b / Ob trzeba c b ; trubleshooting, a potem c b install system in basic graphic mode (zainstaluj system w podstawowym trybie graficznym) i enter. Trzeba pocz b - b wystartuje instalator. Jako i kraj c b angielski oraz USA) b ze wzgl na b klawiatury QWERTY). V b b na swój kraj, w tym przypadku Europa, Warszawa. Q i b - jest taka - najlepiej b statyczny adres IP, b , c b i DNS-y. Powinno w b partycjonowanie systemu. Dobrze jest w c b system b b b b LVM, ale b inny. Wybór systemu do b b b b masowej b od tego, jaka jest wymagana konfiguracja dysku twardego. Zalecane jest ustawienie osobno partycji dla . System plików zajmuje mniej miejsca i jest o ponad 50% szybszy od , czy .

Zalecany b rozmiar partycji b b w ten sposób:
/boot - 512 MB,
/biosboot - 1024 KB
swap - 6GB) lub RAM),
/ - 30 GB
/usr - 30 GB
/tmp - 30 GB
/var - 30 GB
/home - 100GB (tutaj warto po prostu b taki rozmiar, jaki b do dyspozycji, b b max, ale bezpieczniej jest b rozmiar). Minimalne rozmiary partycji ! b ! b ! : https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/6/html/installation_guide/s2-diskpartrecommend-x86. Po uruchomieniu instalatora z lub pendrive b zgodnie ze wskazówkami. Ob b dla b root oraz konto b-którego b od razu b do grupy administratorów (sudoers). Ob c b b b b - co pozwala w b w etapie serwer do wymaganych potrzeb. Po b instalacji b b b serwer.

Konfiguracja SSH

Ob [b b na serwerze jako root lub z uprawnieniami sudo.
W przypadku dystrybucji z rodziny Debian b AppArmor.

W przypadku dystrybucji z rodziny Red Hat b SELinux

T b - czy jest w trybie enforcing
V b b b systemu:

lub

Ob b plik /etc/ssh/sshd_config i port z 22 na np. 2244. U b PermitRootLogin prohibit-password, aby b b logowanie root.-a

Ob b klucze rsa na serwerze za polecenia:

(nazwa ytkownika @ serwer, na którym generowane klucze)
Ob trzeba b klucz do docelowej maszyny np.

Program poprosi b o b logowania b user, co wynika to z faktu, klucz jeszcze nie b umieszczony we b pliku na zdalnym serwerze. Po b uwierzytelnieniu b ssh-copy-id przeniesie klucz publiczny do odpowiedniej lokacji.
Ob w w sshd_config uwierzytelnianie b i logowania bez b b- a uwierzytelnianie kluczem.

Od tej pory b w sposób bezpieczny zdalnie z serwerem.

Konfiguracja hasła dla GRUB2
Aby b b dla GRUB2 b b b ;

Zostaniemy poproszeni o wpisanie b b b- a b zdefiniowanie b b jedynie dla konta root. E c b - powinno b jest c b o to, aby nie b nazw kont administracyjnych dla administratora b GRUB2. Staramy b b b popularnych nazw kont administracyjnych, takich jak root, administrator lub administrator dla konta b GRUB2.Zaleca - aby b konta administratora programu b c inne dane b e.
Mamy teraz zaszyfrowane b - które musimy b w pliku konfiguracyjnym GRUB2 Bootloader, czyli grub.cfg. Qb taj o tym, by nie b b konta administratora i b b do pliku grub.cfg, b polecenie grub2-mkconfig nadpisuje ten plik. Trzeba w tym przypadku b zaszyfrowane b do niestandardowego menu GRUB2, tj. 40_custom, które znajduje w /etc/grub.d/.
Przed pliku menu 40_custom zalecamy wykonanie najpierw kopii zapasowej tego pliku. W dalszej nazwy konta b/

Dodajemy b user oraz nasz wygenerowany hash w sposób:

WchnzWy5

9. Wykonaj polecenia / Tworzymy specjalnego usera o nazwie dbadm z uprawnieniami, aby sobie z niego b zamiast root do z c b danych serwerpoczty.
   CREATE USER 'dbadm'@'localhost' IDENTIFIED BY 'password';

10. Q na c b danych, aby móc jej b ;

11. Utwórz tabele o nazwie Domeny, Userzy oraz Aliasy.
    Dla domen, które c c b na serwerze

    Dla wszystkich kont e-mail

    Dla wszystkich aliasów

12. Dodaj do tabeli z domenami

13. Dodaj konta mail do tabeli z kontami e-mail

    ENCRYPT('password',

    ENCRYPT('password',

    ENCRYPT('password',

14. Dodaj alias root dla konta admin

15. T b wyniki w tabeli z domenami, b i aliasami

16. Wy poleceniem lub z c bazy danych.
17. Wykonaj pliku konfiguracyjnego postfix

18. Edytuj plik konfiguracyjny postfix

Porównaj plik kopii z tym, co jest p i sysadmin.info.pl b , której c b dla serwera poczty.

Uwaga! Poniższe trzy ustawienia mają szczególne znaczenie. W plikach wskazanych po znaku = skonfigurujesz dostęp Postfix do tabel Domeny, Userzy i Aliasy:

19. Utwórz dla wirtualnych domen plik
    sudo -e /etc/postfix/mariadb-wirtualne-domeny.cf
    wklej:

    wklej:

wklej:

20. Ustaw uprawnienia dla plików

lub

21. [uprawnienia na u b root i postfix, aby ten ostatni
do tych czterech plików . Wykonaj polecenia z sudo.

lub

22. Zrestartuj postfix, dovecot oraz mariadb

23. Przetestuj i wykonaj po b zmianie w konfiguracji dla
V polecenia sudo, aby b komendy. Dla b b powinno
b 1

24. Wykonaj pliku master dla postfix

25. Edytuj:

Porównaj plik z tym, co jest (w b wypadku nie kasuj i nie podmieniaj, jedynie b b i odkomentuj i dodaj c b b tak, jak jest *.

pod scache w sekcji maildrop dodaj: (na razie to b b * jest to b z dovecot_destination_recipient_limit = 1 w main.cf postfixa, co powoduje, mail b do wielu jest rozdzielany i dostarczany po jednym naraz, co b problemy.

DOVECOT

1. Zrób b b dla dovecot.

2. Edytuj plik konfiguracyjny dovecot

   [b na to, czy te linie odkomentowane.)V znak # przed nimi) Q ; / aby b te pozycje jedna po drugiej.

3. Edytuj plik konfiguracyjny dovecot

   Ustaw element w pliku tak, jak wg wzorca:

4. Utwórz katalog
5. Dodaj wpoczta
6. Dodaj b wpoczta
7. Nadaj uprawnienia dla b i grupy wpoczta

8. W /etc/dovecot/conf.d/10-auth.conf tylko uwierzytelnianie za SQL i pozostaw inne metody uwierzytelniania w spokoju.

   Wyszukaj i w razie potrzeby odkomentuj b znak #

9. Edytuj plik auth-sql.conf.ext i ustaw tak, jak /

10. Edytuj plik dovecot-sql.conf.ext i wklej b b

11. [uprawnienia do katalogu dovecot dla b wpoczta i grupy dovecot.

12. Edytuj plik 10-master.conf i ustaw jak na b /

13. Edytuj plik 10-ssl.conf odkomentuj ssl = required i b klucze tym, co

14. Edytuj plik 10- logging.conf

15. Ob po zapisaniu zmiany do pliku log dla dovecot.

16. Zainstaluj i wygeneruj klucze letsencrypt

    dodaj to do crontab:

    To powoduje b certyfikatu co 12 godzin, czyli zgodnie z zasadami encrypt. https://letsencrypt.org/docs/rate-limits/ .
    Nie zrobi niczego, dopóki certyfikat nie zostanie odnowiony lub b - ale regularne uruchamianie go da b korzystania z OnApp CP w trybie online w przypadku, gdy z b powodu b b zainicjowane przez szyfrowanie.

17. Zainstaluj mailx do bnia maila testowego, a potem mailx

    X ctrl+d

18. T b w logach informacje o b b maila.

19. Dodaj dla portów w firewalld

20. Zainstaluj sieve poleceniem:

    Wyedytuj plik

    Ustaw b jak ;

21. Wyedytuj plik

    Dodaj ustawienia:

22. T b czy SELinux jest w trybie permissive

23. X tryb enforcing

24. N sam koniec ustawienia SELinux i daj do katalogu domowego, b inaczej postfix ani dovecot nie c do niego i nie c w stanie b b i b z niego maili.

Konfiguracja serwera WWW w systemie Debian 9.8.0

Serwer bazy danych serwer z CentOS 7.6, na którym jest zainstalowana baza danych.
Server www: Serwer z Debian 9.8.0, na którym jest zainstalowany WordPress.
baza_wp: Nazwa bazy danych.
wp_uzytk: V klient bazy danych WordPress
ElF@9GoSvshO0Fn4P&MN: b b bazy danych SQL baza_wp.
150.10.0.11: Prywatny adres I serwera bazy danych.
150.10.0.10: Prywatny adres I serwera w
deb_usr: Lokalny z prawami sudo, który nie jest rootem.
176.105.137.72/sysadmin.info.pl: Publiczny adres serwera , lub nazwa domeny (FQDN).

1. Zainstaluj serwer bazy danych MariaDB 10.3 w CentOS b ! b:

   wklej b b ;

   Zapisz insert Esc :wq Enter

2. Zainstaluj serwer MariaDB oraz klienta:

3. Wystartuj MariaDB serwer

4. X na b serwer MariaDB

5. T b status MariaDB

6. Uruchom c MariaDB poleceniem, b nie masz nadanego b b b root bazy danych.

7. Po zalogowaniu ustal has roota do MariaDB poleceniem:

   'password';

8. Zaloguj do MariaDB ustalonym b ;

9. T b status MariaDB:

10. Wykonaj polecenie:

11. X okno, w którym na pytanie o b b b root odpowiadasz n, b ustalone b / Q b pozycje potwierdzasz b Y.

12. W CentOS firewall jest zainstalowany ie. T b - czy jest /

13. Listowanie portów i serwisów firewall

14. Dodaj mysql

15. Zrestartuj firewall

16. V lub portu. Nie jest to potrzebne w tym momencie, ale b / Z portu 3360 korzysta MariaDB oraz MySQL. K li chcesz b ten port zamiast - co czasem c b problemu, to b remove add.

17. Zaloguj do MariaDB
    sudo mysql -u root -p

18. Wykonaj polecenie aby b c b danych o nazwie baza_wp

19. Wykonaj polecenie, aby b- który c b z tej bazy. Nie powinien c to root ze c b/

'password';

20. Przydziel uprawnienia wp_uzytk

21. Utwórz b oraz przydziel uprawnienia do zdalnego do bazy danych baza_wp dla b wp_uzytk. Adres IP to lokalny adres IP serwera www, na którym znajduje WordPress. I b jest takie samo, jak b b- utworzonego /
    CREATE USER 'wp_uzytk'@'150.10.0.10' IDENTIFIED BY 'password';

    `wp_uzytk`@`localhost` IDENTIFIED BY 'password';

    `wp_uzytk`@`150.10.0.10` IDENTIFIED BY 'password';
22. Wykonaj polecenia:

23. T b - czy w stanie b b stworzonym ;

24. Na serwerze www z Debian wykonaj b polecenie:

25. T b - czy b b przy pomocy polecenia:

    b b; ElF@9GoSvshO0Fn4P&MN
26. T b status MariaDB

27. Zamknij z MariaDB.

28. Utwórz katalog o nazwie src w katalogu swojej witryny, aby b nowe kopie plików WordPress. W tym przewodniku jako b wykorzystano katalog domowy /var/www/html/sysadmin.info.pl/. Q do tego nowego katalogu:

29. Ustaw b serwera WWW, www-data, jako b b katalogu domowego swojej witryny. www-data jest /

30. Zainstaluj b WordPress i wypakuj ;

31. [b pliku latest.tar.gz na wordpress, a b ustaw b przechowywania kopii zapasowej oryginalnych plików / C to przydatne, zainstalujesz nowe wersje w i c potrzeba do poprzedniej wersji:

32. Utwórz katalog public_html, który c katalogiem WordPress. Q pliki WordPress do folderu public_html:

33. Nadaj folderowi public_html uprawnienia dla grupy www-data:

34. Q do katalogu, do którego c WordPress, skopiuj b b i ustaw tak, aby b b ze zdalnej bazy danych:

35. [zmienne logowania tak, aby b b do bazy danych i b/ [b 150.10.0.11 prywatnym adresem IP serwera bazy danych. Wyedytuj plik:

36. Dodaj klucze c b- aby bc wp-b /V Generatora kluczy c b WordPress, aby losowe, skomplikowane hashe, których WordPress do zaszyfrowania danych logowania. Skopiuj wynik i b w pliku wp-config.php:

37. Zabezpieczenie ruchu do i z bazy danych WordPress za pomocą SSL

E CentOS ma utworzony katalog z certyfikatami i nie trzeba b katalogu / X do niego b;

38. Wygeneruj klucz certyfikacji i utwórz certyfikat oraz klucz prywatny. Odpowiadaj na odpowiednie monity. Klucz w tym b wygasa za 100 lat. [b dni 36500 w tym i b krokach, aby b certyfikaty do b b w razie potrzeby:

Common Name ustaw na MariaDB

39. Utwórz certyfikat serwera i zapisz klucz RSA. Nazwa b (common name) powinna c b FQDN lub adresem IP twojego serwera WWW. W tym przypadku: sysadmin.info.pl

40. Podpisz certyfikat:

41. Q klucze i certyfikat na b miejsce:

42. Wygeneruj klucz klienta. Odpowiadaj na odpowiednie monity i ustaw b na FQDN lub adres IP swojego serwera WWW: sysadmin.info.pl

43. Zapisz jako klucz RSA

44. Podpisz certyfikat klienta

45. Zweryfikuj certyfikaty

46. Powinien przy obu OK.
47. Wyedytuj plik server.cnf na CentOS

48. Dodaj w sekcji [mysqld]:

49. [b b b #bind-address, # , co spowoduje odkomentowanie i ustaw jak / Adres IP na lokalny adres IP serwera CentOS, na którym jest zainstalowana baza danych MariaDB.

    X ctrl+o, a b ctrl+x
50. Q plik server-key do folderu private

51. Zaloguj do MariaDB i wymagaj SSL dla wszystkich b do bazy danych. [b 150.10.0.10 prywatnym adresem IP

52. Zrestartuj serwer MariaDB:

53. Skopiuj certyfikaty i klucz do serwera WWW. [b b deb_usr na b serwera WWW, a 150.10.0.10 na prywatny adres IP serwera WWW:

54. Na serwerze www utwórz katalog i certyfikaty i klucz do /etc/mysql/ssl:

55. K katalog /etc/mysql/ssl istnieje, to wykonaj samo polecenie po znakach &&.

56. Skonfiguruj klienta MariaDB serwera WWW do korzystania z SSL. [b [mysql] w pliku 50-mysql-clients.cnf i dodaj lokalizacje dla certyfikatów i klucza:

57. Wklej b b w sekcji [mysql]

58. Zaloguj z serwera www z Debian do serwera bazy danych MariaDB z CentOS przy pomocy polecenia:

59. K - zostanie wiersz b MariaDB. Wpisz polecenie:

60. Dodaj przed b c b danych w wp-config, która zmusza WordPress do b b SSL do b z c b danych:

61. Uzyskaj do interfejsu instalacyjnego WordPress poprzez wp-admin. V b - aby do sysadmin.info.pl/wp-admin. K z c b danych b powodzeniem, zobaczysz ekran instalacji:
62. Utworzenie logów dla MariaDB

63. systemctl status mariadb pokazuje c ;

64. S b ;

65. C ;

66. S b ;

67. po upgrade

Konfiguracja serwera plików Samba w systemie Fedora 29
Instalacja Samby

1. Zainstaluj serwer Samba 4.9.5 w Fedora 29 poleceniem:

   Po chwili mamy b b b w komputerze. Jej systemowa nazwa to smbd i nmbd, przyda nam to / Q do b b - czyli konfiguracji.
2. Do firewall trzeba b b b na b b Samby

Konfiguracja Samby

3. H plik konfiguracyjny Samby zlokalizowany jest w /etc/samba/smb.conf.
4. Ob ! b b b pliku Samby:
5. Plik jest b b , ! ! ! ! b ! c ! b b ! b administratora.
6. Konfiguracja Samby polega na konfiguracji pozycji.
   - W tej sekcji b ! ustawienia globalne, które wszystkich /
   - Nazwa grupy pochodzi z systemu Microsoft Windows. Ob ! b ! b ! b ! ! b ! b ! b ! ! ! ! W przypadku instalacji systemu Microsoft Windows w wersji polskiej, jest to: GRUPA_ROBOCZA, w przypadku wersji angielskiej WORKGROUP.
   - Pod b jest widoczny serwer w lokalnym otoczeniu sieciowym.
   - K ! ! ! ! b b ! b ! b ! b ! ! b Tb c b H ! b ! b b b c b c ! b b c b ! ! ! b c ! b b ! b ! b ! ! b- natomiast w przypadku ustawienia opcji share, nie trzeba ! c . Ob b) symbol #).
   - Q ! ! ! b ! b ! b /
   - Ub b b ! ! ! ! b b ! b ! b b/
   - U ! b ! ! b ! b ! b b ! c ! ! ! ! b b ! ! b Tb c b b ! b b ! /
   - E b Share Definitions odpowiadzialny jest za katalogi, które b ! ! / N b w tym miejscu ich uprawnienia, np. atrybut tylko do odczytu.

Security share

7. W przypadku, kiedy jako administrator nie chcemy tworzy b - a jedynie chcemy wszystkim innym w sieci swoje pliki, b ! w pliku konfiguracyjnym Samby b security na share.

8. Nb b ! c zmie te opcje, które b ! ! ! ! b /

9. X ! b ! ! c b b ! dodatkowe opcje na u konfiguracji w sekcji [global] b ! b ! ! ! b ! :

- ! b ! b ! ! b b ! b serwera Samba w otoczeniu sieciowym
- b b b b ! b ! b Tb c b ! ! /! Qb b ! ! ! serwer w ogóle nie jest widoczny w otoczeniu sieciowym, co jest b ze c b/
- potrzebne do b komunikacji serwerem, a klientami

Udostępnianie publiczne w Samba

10. K istnieje potrzeba, aby wszystkim b folder Anonymous - b w katalogu /srv/samba, b b polecenia:

11. Ob kontekst c b SELinux dla katalogu samby w b sposób:

12. Ob trzeba plik konfiguracyjny Samby do edycji, w którym b b 0 b b sekcje wraz z odpowiednimi dyrektywami.

13. Ob b wpis na samym u pliku konfiguracyjnego Samby:

- nazwa b zasobu
- b do niego
- b czy zasób ten b b
- b to czy b w nim b b i b pliki
- b jakie prawa b nowo tworzone w nim pliki
- odnosi do praw tworzonych folderów
- b b opcja, bez niej c nam b b okienko logowania w Windowsie, kiedy c chcieli zasób, a i tak nie zalogujemy, bo nie jeszcze b /

14. Teraz b aktualne ustawienia Samby, polecenie.

15. Ob b uruchamianie Samby przy starcie systemu oraz poleceniami:

16. Po chwili serwer Samba powinien c widoczny w otoczeniu sieciowym pod b Samba. J do niego wedze, w

ili

do aiu nieni

ev

v do zstar4(towae)4(niu)] TJETQq0.00000887

tylko do odczytu dla innych, c to - b nas opcje w konfiguracji samby:

D temu wszystkie tworzone pliki i katalogi c b uprawnienia 777.

27. Dla potrzeb c b b foldery dla konkretnych grup /
28. W tym celu b b b polecenia:

Utworzony b katalog secure i nadano grupie smbgrp uprawnienia do niego. Ostatnie polecenie zmienia kontekst c b SELinux dla katalogu ielonego Samby.

29. O b b edycji pliku konfiguracyjnego Samby poleceniem:
30. X b na samym parametry

- b dla grupy smbgrp. Tylko tej grupy c do tego folderu i prawo zapisu do niego.

31. Ponownie, b ustawienia konfiguracji samby, b /

$ sudo testparm

32. Uruchom ponownie Samba, aby b b zmiany.
33. Q do maszyny z systemem Windows, otwórz #T # z okna Eksploratora Windows, b kliknij na hosta Samba, lub spróbuj b do serwera b jego adresu IP.

\\150.10.0.12

34. Zostaniesz poproszony o podanie nazwy b i b b do logowania na serwerze Samba. Po wprowadzeniu danych b kliknij OK.

Mapowanie dysków w Windows

35. Teraz wystarczy w Windows b b jako dysk sieciowy b przez Tb c zasób.

2.5. Dobre praktyki administracyjne i polityka użyt

X!TNû2.ÆE$ÿYS(AñcU0A@zLONEÿYS(AñÒ2ɑ$ÿYS(AñÒA'0A@È

Gdy nie ma b z tych systemów, zaleca ich b b b od rozmiarów organizacji.

5. **Konta współdzielone**
   Konta b - której b c b /
6. **Szyfrowanie dysków**
   - Szyfruj dyski, gdy tylko jest to uzasadnione i wymaga tego polityka firmy, lub administrujesz systemami, które nie restartowane, a b b poufne dane. Ewentualnie przenosisz dyski biurami. Szyfrowanie dysków jest nieuzasadnione, gdy b b lub spowalnia cykl pracy. Ostatecznie c stanowi b b niami i - a wyznaczenie odpowiedniej granicy nie jest b zadaniem.
   - Ob b dane / Nawet administrator zapomni dane na dysku przed wycofaniem go z - b - informacje w bazie danych nadal c bezpieczne.
7. **Zasada najmniejszych przywilejów**
   - Zgodnie z b powinien b tylko minimalnym poziomem b - takim, który jest c do wykonania pracy, i nic ponadto.
   - W przypadku i serwerów b b najmniejszych przywilejów najbardziej c stosuje w odniesieniu do zapór firewall. K b nie musi b z - to nie b jej na to b b / Wynika logiczny wniosek, administrator powinien zapory firewall, które c b ruch - a b b na ruch tylko tym - które b - by móc b b / K b nie wymaga do b b b b b root, to nie powinna b b z b b root, ale z b mniej uprzywilejowanego b/
8. **Obrona w głąb**
   - Cb otoczenie sieciowe powinno c traktowane jako potencjalnie wrogie /
   - Kb b warstwa sieci powinna b b ruch z innych sieci.
   - Kb serwer powinien swoje b - lokalne programowe zapory firewall.
   - Do logowania do maszyn b b klucze SSH, które powinny c chronione b /
   - Ob b mechanizmy TLS w celu zabezpieczenia ruchu sieciowego.
   - Uwierzytelnianie serwera dla klientów b b przy certyfikatów.
9. **Dbałość o proste procedury i schematy**
   - Ob b c b o prosty schemat sieci, który pokazuje dane b e prostymi liniami w stosu, co pozwala b go i bc /
   - Ob b b c b o proste listy kontroli (ACL).
   - E prostym zabez i prostym systemom b jest analiza wszystkich scenariuszy ataku, wykrycie bc punktów w projektach i szybsze znalezienie b lub c .
10. **Zabezpieczanie haseł**
    - Ob b b b o minimalnej 12 znaków, w tym i b litery, cyfry oraz znaki specjalne.
    - Zabrania b b tego samego b b do wszystkich kont.

- Ob c b próby b b b b b bez na / Trzykrotne wpisanie c b b skutkuje banem. Q b oprogramowanie, które b b b ; fail2ban.
- Tam, gdzie to - stosuj b uwierzytelnianie.
- Gdy istnieje - powinno - znane logowania do serwisów.

11. Ustawienie niestandardowych portów dla usług

W b b b c b o ustawienie niestandardowych portów dla SSH.

12. Kompartmentalizacja

- Ob b b na wydzielonym serwerze. E temu, b b b do jednej z - b b infrastruktury pozostanie bezpieczna.
- Zabrania przechowywania wszystkich danych w jednej bazie danych.
- Zabrania przechowywania wszystkich b plików na jednym serwerze.
- K administrator korzysta z wielu - które c przechowywania danych w bazie danych, b b z nich powinna b c b dla swoich danych.
- Ob b umieszczania sieciowych w tej samej podsieci. Powinny c one odizolowane w b /

13. Zasady kont i grup

- Q ! ! c b ! b ! ! ! ! ! ! !
- S !b b ! b ! ! ! ! ! ! b ! ! dokumentacji w postaci elektronicznej tworzonych kont ! Ob ! b b ! ! b ! b ! ! b ! ! ! ! c Q b ! b ! !c ! ! b ! ! ! ! ! ! ! ! ! nowego pracownika, co wymaga utworzenia grup z poszczególnymi rolami oraz ko ! !c ! b ! ! .
- X ! ! b ! b ! ! b ! c! ! b ! b b ! b b ! ! ! ! ! ! b b ! b c b ! ! b ! ! c ! ! b ! ! ! b b b ! ! ! ! ! ! ! .
- Ob ! b ! c ! b ! b ! ! ! ! b . Q ! ! b ! ! b ! b ! przyjmowania nowych pracowników, jak i ic ! b b b. S ! ! b ! b ! ! b ! ! ! ! ! b ! ! ! b ! b ! b b ! c! b ! ! ! ! ! b ! .
- [b b ! b b ! b ! ! b ! ! ! ! ! ! zleceniach roboczych, najlepiej w p b ! ! . Ub ! ! b ! c b! ! b b ! b ! b ! ! b b ! ! ! c ! b ! ! ! /

Dobre praktyki administracyjne

1. Ob b c b o to, aby nie b nazw kont administracyjnych dla administratora b GRUB2. Powinno b b b popularnych nazw kont administracyjnych, takich jak root, administrator lub administrator dla konta b GRUB2.Zaleca - aby b konta administratora programu b c inne dane b /
2. E c b jest, aby nie bc b dysku twardego b w BIOS, lecz jedynie b b - co sprawi, BIOS nie c b o b po b zaplanowanym restarcie serwera.
3. E c b jest wymaganie szyfrów o sile (ang. *medium*), czemu b b b ze zdalnymi serwerami pocztowymi bez dopuszczania niektórych bc szyfrów.
4. Ob b oznaczone jako spam do specjalnego folderu o nazwie spam lub junk.
5. K to adresy IP, nazwy hostów, identyfikatory i grup powinny c b b centralnie.
6. P c b b b po stronie specjalistycznego.
7. Kontrola sieciowych systemów plików b do wyznaczonego w tym celu /
8. Usuwanie z systemu powinno c b do 30 dni po ich z organizacji. Lista identyfikatorów pracowników powinna c przekazywana co do administratora.
9. Administrator c any jest do c b b c prawami autorskimi.
10. Administrator c b jest do stworzenia schematu sieci informatycznej organizacji i jej aktualizacji.
11. Ob b c b o stworzenie procedury kopii zapasowych i ich regularne wykonywanie.
12. Warto SLA (ang. *Service Level Agreements*), które definiuje sposób i czas wykonywania poszczególnych /
13. Ob b c b o b i wszelkie jej naruszenia powinny c b b na odpowiedni adres e-mail.
14. Zagadnienia prawne b do prawników, jednak administrator powinien b b b w przypadku instalacji, konfiguracji i utrzymania na serwerze licencjonowanego oprogramowania.
15. Do Administratora b poinformowanie ników poprzez informacje powitalne w skryptach startowych nowo skonfigurowanego systemu. K do zdalnego logowania jest wykorzystywany SSH, b b plik sshd_config w taki sposób, aby komunikat c b w powitaniu sesji SSH.
16. Ob informatyczne w organizacji, które jednoznacznie b - nie maja prawa b zasobów organizacji do nielegalnych celów.
17. Administrator powinien w sposób poprzez szkolenia i programy certyfikacyjne, a b konferencje informatyczne.

3. Podsumowanie

Gdy zrozumie pewne ogólne zasady c b- b je b b do dowolnego problemu, który ma do b b jako administrator serwerów, bez na to, czy jest to hartowanie konkretnej - czy decyzji, która dotyczy projektu infrastruktury nowej aplikacji. W b od konkretnego b i b - które w nim stosowane przez administratora podejmowane adekwatnie do sytuacji, jednak ogólne zasady c zawsze. Takie samo zastosowane jest do rodzajów problemów w b z b b w tej pracy. W rozdziale pierwszym b b te zasady przy wybieraniu b BIOS, GRUB2 oraz kont - w rozdziale drugim podczas zabezpieczania logowania sieciowego i wreszcie w podrozdziale 2.2 i 2.3, podczas konfiguracji kont e-mail w bazie danych oraz kont Samby. W ramach preferowanej strategii b b za - do wyboru b b z minimum 12 znaków oraz bez b b b ze / [b b obrony w c - b sól do b oraz bc b b b - tak, aby ich b b oraz b / Q b b - b od b b na serwerze jest wykorzystanie kilku podstawowych metod hartowania.

W rozdziale pierwszym na b utwardzania, które b b b do b dowolnego serwera. W b hartowanie b root za polecenia sudo oraz znaczenie mechanizmów logowania b w dziennikach. Ponadto, c pod b - obecnie prawie na b serwerze b SSH do zdalnej administracji, kilka technik hartowania tej od ogólnego hartowania konfiguracji serwera SSH, które polega na logowania jako root, a na do uwierzytelniania kluczy SSH zamiast b b/ P b zabezpieczanie sieci i b b - jest to proces wielopoziomowy. Pierwsza warstwa polega na wykorzystaniu zapory firewall po to, aby w sieci tylko na dozwolony ruch i bc b ruch, który nie jest uprawniony. Ob b warstwa jest odpowiedzialna za zabezpieczenie uprawnionego ruchu sieciowego przed przechwyceniem. Do tego celu stosuje szyfrowanie TLS oraz SSL.

W rozdziale drugim b b informacje o tym jak jest ich wzmacnianie w celu b b b atakom. W tym rozdziale

sposoby wzmacniania serwerów WWW i poczty. [b od omówienia konfiguracji HTTPS, które pozwala b zarówno poprzez szyfrowanie ruchu WWW, jak i zapewnienie sposobu uwierzytelniania serwera. [b b sposób wprowadzania zaawansowanej konfiguracji, która pozwala na zabezpieczenie przed atakami na b HTTPS, takimi jak ataki degradacji / P b mechanizmy b b b zapory WAF, której konfiguracja znajduje w instrukcji.

W drugiej podroz b 2.1 b na zabezpieczenia PHP ze szczególnym naciskiem na c i b b w jaki sposób b b FastCGI do przetwarzania plików PHP, co jest jedynym bezpiecznym b / K jakakolwiek infrastruktury w firmie przechowuje cenne dane, to jest warstwa bazy danych. Nawet te organizacje, które do bc nieco - powinny w zabezpieczenie baz danych i je c sieci.

W paragrafie 2.1.3 szereg kroków, które b w celu wzmocnienia bc bazy danych od podstawowych, b na lokalizacji bazy danych w sieci, poprzez sposoby jej bezpiecznego administrowania, a na konfigurowaniu b /

Na koniec w instrukcji b b b serwera b - w jaki sposób b do bazy danych przez - b z bc komunikacji z c b danych za szyfrowania TLS.

W podrozdziale 2.2 na hartowaniu serwera poczty. Jak b b c b - b z utwardzaniem systemu pocztowego skupia na tym, aby zapobiec b spamu. W 1. c b - jak nie do b b serwera w system open relay. W 2. zagadnienia uwierzytelniania poczty oraz zabezpieczania ruchu e-mail za TLS. Na koniec w trzeciej, czwartej, i szóstej tego b zaawansowane metody ochrony przed spamem i wirusami za SpamAssassin, ClamAV oraz Fail2ban. Obecnie coraz serwerów dostawców pocztowych posiada zaimplementowane wszystkie opisane mechanizmy w celu wzmocnienia swoich serwerów. Administratorzy o tym, inne legalne serwery poczty elektronicznej w internecie te same mechanizmy. Im mniej opisanych zaimplementujemy, tym b c - zdalny serwer uzna b b za spam, nawet, gdy

zaakceptuje. K dla administratora jest to istotna kwestia, aby b e-mail b b dostarczona i nie b b oznaczona jako spam, to zdecydowanie powinien on b zastosowanie wszystkich zaawansowanych z zakresu hartowania.

W podrozdziale 2.3 b krótko b b b z SMB w wersji 1 oraz oprogramowaniem Samba, które pozwala serwer plików b b pracy pod bc i po odpowiednim zabezpieczeniu oferuje dobry poziom c b/

Praca ta ma za zadanie b b - w jaki sposób b bc systemy przed b b b / Jednak b od tego, jak wielki podejmiemy, napastnikowi nadal b prz nad z systemów. Ob o tym, temat c b serwerów nie b b wyczerpany, b bc przed skanowaniem moich serwerów oraz ich poziom c b- zmuszony b do implementacji na serwerze poczty SPF, DKMF oraz DMARC. Dodatkowo b b b tripwire do sprawdzania b systemu plików, snort, który powiadamia mnie o skanowaniu portów serwera oraz logwatch, który b raporty na mój adres e-mail jako administratora serwera poczty. Ob - z b kwestii jest robienie kopii zapasowych danych b na serwerach, b ataki ransomware b b coraz / Dlatego w zakresie nieoficjalnych c administratora rozwój wiedzy w zakresie szeroko c b/

4. Bibliografia

4.1. Publikacje książkowe:

[1] Matotek D., Turnbull J., Lieverdink P.; Profesjonalne administrowanie systemem; Wyd. II, Gliwice 2018, HELION, s. 454

[2] Nemeth E., Snyder G., Hein T. R., Whaley B., Mackin D., Garnett J., Branca F., Mouat A.; Unix i Linux Przewodnik Administratora Systemów; Wyd. V, Gliwice 2018, HELION, s. 1046

[3] Rankin K.; Hartowanie Linuksa we wrogich b ! /P ł serwera od TLS po Tor; Wyd. Gliwice 2018, HELION

4.2. Strony internetowe:

[i1] Red Hat Training - 3.3. Confined and Unconfined Users, https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/selinux_users_and_administrators_guide/sect-security-enhanced_linux-targeted_policy-confined_and_unconfined_users , ł ! 26-03-2019,

[i2] Red Hat Training - Chapter 50. Working With SELinux, https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/5/html/deployment_guide/rhlcommon-chapter-0017, na dz ! 26-03-2019

[i3] W3Techs - Usage of content management systems, https://w3techs.com/technologies/overview/content_management/all, ł ! 15-03-2019

[i4] obfusc.at/ed - Bb ! ! , http://obfusc.at/ed/bayes_filtering_pl.html, ł ! 26-03-2019

[i5] sieve.info - What is Sieve?, http://sieve.info/, ł ! 26-03-2019

[i6] Red Hat Training - 9.15.5. Recommended Partitioning Scheme, https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/6/html/installation_guide/s2-diskpartrecommend-x86 , ł ! 26-03-2019

Copy protected with Online-PDF-No-Copy.com